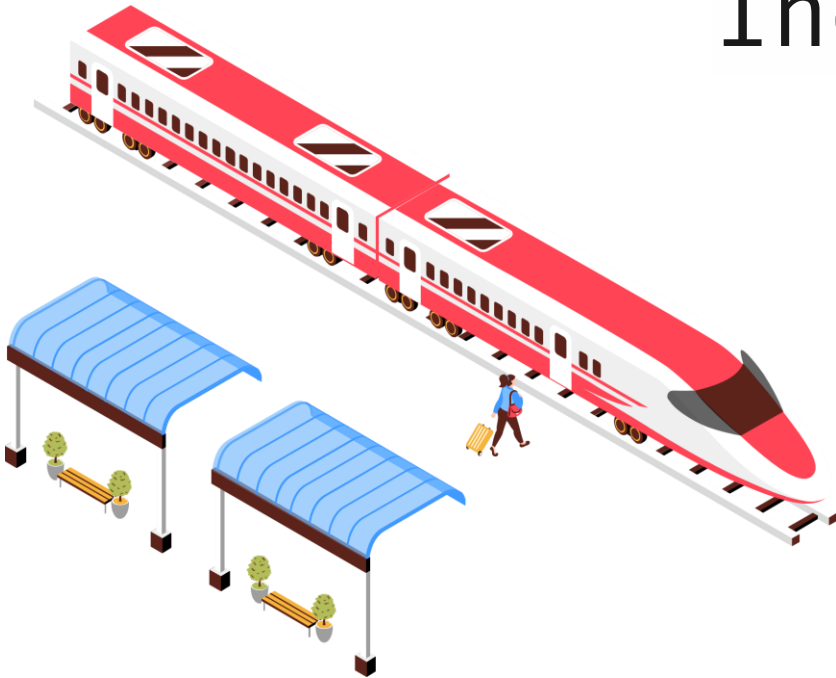


# Cyber-security in Industrial Control Systems



**Kawtar Zerhouni, Maîtresse de conférences  
UTER MID@S - ECC**



# CM1 : Introduction to Industrial Cybersecurity

---

- We explored Industrial Control Systems, their component and their importance.
- We introduced CIA triad
- We looked at key differences between IT and OT systems

*Wait, what exactly are we aiming to safeguard ICS systems against?*

***Threats landscape***



# CM2 : Threats and vulnerabilities

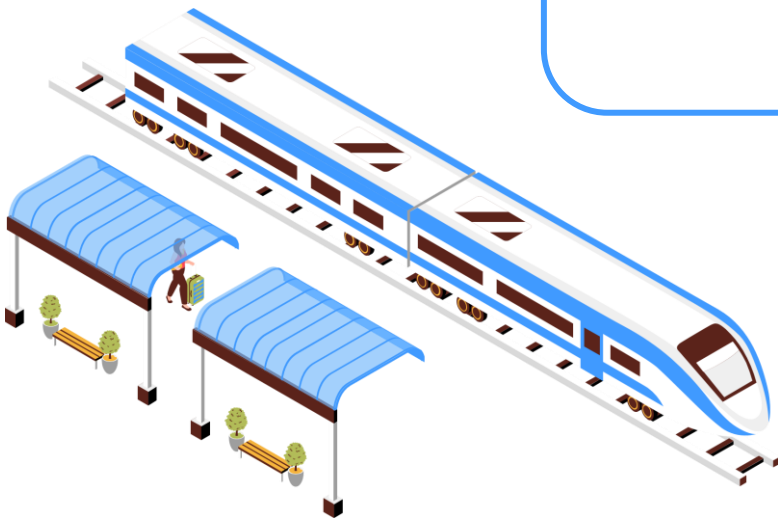
---

- We explored possible threats and attacks to ICS
- We identified vulnerabilities that enable these threats.
- We presented some vulnerability analysis tools
- We introduced risk assessment processing paving our way to Risk Score per vulnerability Calculation

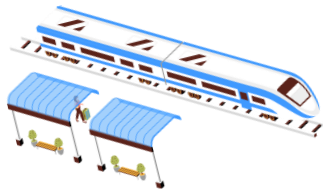
*What actions should we do to prevent these incidents ?*

***Security Monitoring***

# Security Monitoring

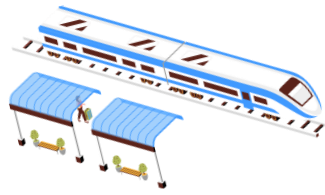


# What is security monitoring ?



- Continuously monitors activity within the ICS network to **identify** suspicious behavior or **potential** security incidents.
- Aims to provide **early warning signs** of potential attacks or vulnerabilities that could be exploited.

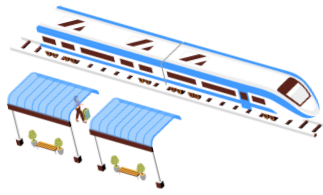
# What is security monitoring ?



- Depending on the discovered security incident, response actions are either **corrective** or **preventative** in nature.
  - **Incident Response (IR, CM4)** activities are an example of **corrective** response actions.
  - **Preventative** response actions are all about correcting failing or lacking existing security controls or adding additional security controls to prevent a security incident from occurring again.
- The changing or adding of firewall rules as a response to detection of malicious activities on the network.

# Types of security monitoring

---



3 main types :

- **Passive security monitoring**
- Active security monitoring
- Threat hunting



# Passive security monitoring

**Passive** says it all !

- Passive security monitoring operates on the principle of **non-interaction** with the monitored environment.

*It abstains from actions like modifying files, configurations, or transmitting packets across a network.*

The approach involves a **watch-and-observe** methodology.

- Monitoring focuses on detecting changes in files, configurations, and observing network traffic.
- The aim is to identify signs of malicious behavior without directly engaging with the environment.





# Passive security monitoring : techniques

---

Forms of passive security monitoring include the following:

- **Network packet sniffing** for the detection of malicious activity
- The **collection and correlation of event logs** to identify malicious behavior/activity
- **Host-based security** solution agents collecting **system statistics** to discover malicious activities



# Passive security monitoring : techniques

---

Forms of passive security monitoring include the following:

- ***Network packet sniffing for the detection of malicious activity***
- The collection and correlation of event logs to identify malicious behavior/activity
- Host-based security solution agents collecting system statistics to discover malicious activities



# Passive security monitoring : techniques

## Network packet sniffing: promiscuous mode

- It involves examining traffic within the network segment under observation.
- Typically, **network interface cards (NICs)** filter and pass only pertinent network packets, i.e., those addressed to the NIC's **MAC address** or sent to the **broadcast address** for the network segment.
- However, when the network card is set to **promiscuous mode**, it forwards every packet it detects.
- Using tools like **Wireshark**, we can examine each network packet passing through the sniffing interface.
- This enables the identification of anomalies, patterns, Internet Protocol (IP) addresses, intriguing packet data, and other pertinent information.



# Passive security monitoring : techniques

## Network packet sniffing

- Let's look at the following example:

Wireshark - Packet 12 - eth1

```
▶ Frame 12: 88 bytes on wire (704 bits), 88 bytes captured (704 bits) on interface eth1, id 0
▶ Ethernet II, Src: VMware_2a:d2:19 (00:0c:29:2a:d2:19), Dst: VMware_3a:79:e9 (00:0c:29:3a:79:e9)
▶ Internet Protocol Version 4, Src: 192.168.180.222, Dst: 192.168.180.130
▶ Transmission Control Protocol, Src Port: 57746, Dst Port: 21, Seq: 19, Ack: 55, Len: 22
▼ File Transfer Protocol (FTP)
  ▼ PASS Secret_Passw0rd\r\n
    Request command: PASS
    Request arg: Secret_Passw0rd
    [Current working directory: ]
```

|      |                                                 |                   |
|------|-------------------------------------------------|-------------------|
| 0000 | 00 0c 29 3a 79 e9 00 0c 29 2a d2 19 08 00 45 10 | ..):y... )*....E. |
| 0010 | 00 4a 21 51 40 00 40 06 2e 9b c0 a8 b4 de c0 a8 | ..J!Q@.@. ....    |
| 0020 | b4 82 e1 92 00 15 7b c6 fb de 82 2e 39 8a 80 18 | .....{. ....9...  |
| 0030 | 01 f6 ea ee 00 00 01 01 08 0a 12 44 85 f0 00 06 | .....D...         |
| 0040 | 7b 89 50 41 53 53 20 53 65 63 72 65 74 5f 50 61 | {.PASS S ecret_Pa |
| 0050 | 73 73 77 30 72 64 0d 0a                         | ssw0rd..          |

Close Help

**Notice anything suspicious ?**



# Passive security monitoring : techniques

## Network packet sniffing: SPAN ports and Choke points

- Promiscuous mode on NIC allows viewing **all traffic** within the connected network segment.
- A network can establish a **SPAN (Switched Port Analyzer)** session to **mirror** all packets traversing an entire switch, a single VLAN, or multiple VLANs.
- A **dedicated interface** is designated for SPAN sessions, enabling packet sniffing across **specified network segments or interfaces**.
- Typically, a SPAN port is assigned for connecting a NIC in promiscuous mode, facilitating the transmission of packets to a passive security monitoring solution.
- This setup expands the visibility of the monitoring solution from a single network segment to encompassing an entire switch.



# Passive security monitoring : techniques

## Network packet sniffing: SPAN ports and Choke points

- **Choke points** are **strategic locations** in the network architecture where **inter-zone** network traffic is tunneled through.
- The intention behind choke points is to facilitate convenient and effective sniffing of network traffic.

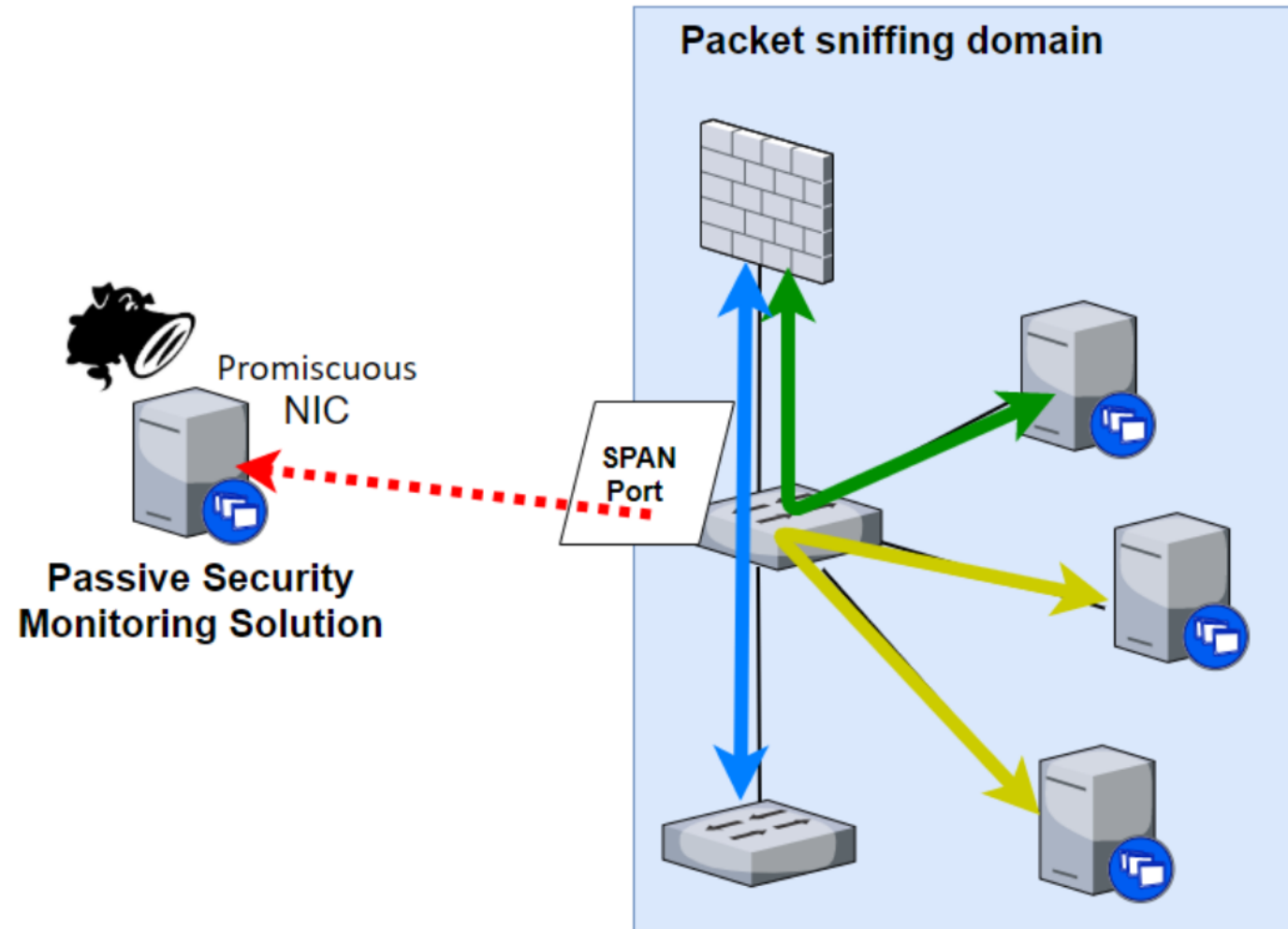
*By setting up a SPAN port session on a strategically chosen switch (the choke point), a **packet-sniffing domain** is effectively created.*

- This domain captures traffic flowing between servers and other sections of the network.

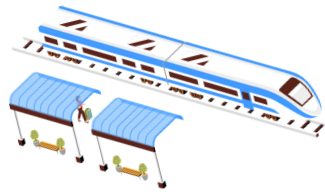


# Passive security monitoring : techniques

## Network packet sniffing: SPAN ports and Choke points



# Passive security monitoring : techniques



Forms of passive security monitoring include the following:

- Network packet sniffing for the detection of malicious activity
- ***The collection and correlation of event logs to identify malicious behavior/activity***
- Host-based security solution agents collecting system statistics to discover malicious activities





# Passive security monitoring : techniques

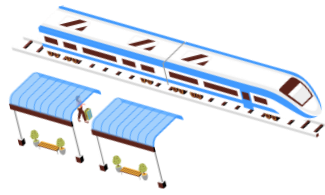
---

## Collection and correlation of event logs

- Event logs consist of **fragments of information** produced by the majority, if not all, network-connected systems.
- They may encompass details regarding the **system's status, modifications made to it, user logins, and operational data** like anomaly detection, identification of malicious code or actions, blocked network connections, and more.

***The challenge is in the effort to collect, store, and be able to correlate all these events.***

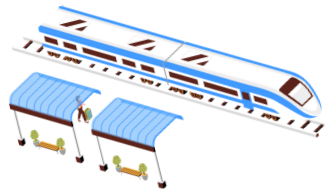
# Passive security monitoring : techniques



## Collection and correlation of event logs

- Gathering event logs from **diverse systems, applications, standards, and formats** poses the initial challenge.
- Solutions often involve choosing between options like using native support for the **System Logging Protocol (syslog)** or **installing agent software on endpoints**, as seen with Windows event logs.

# Passive security monitoring : techniques



## Collection and correlation of event logs

An example of Apache event log, a plaintext file that can be viewed with a text editor:

```
37 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.bat|dir HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
38 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.eml HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
39 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.sql HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
40 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.cobalt HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
41 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.txt HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
42 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.box HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
43 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.nl HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
44 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.cwr HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
45 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.log HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
46 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.shtm HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
47 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.shtml HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
48 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.tmp HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
49 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.JSP HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
50 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.passwd HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
51 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.asp+ HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
52 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.no HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
53 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.TXT HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
54 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.php4 HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
55 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.cmd HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
56 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.config HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
57 127.0.0.1 - - [15/Aug/2020:11:52:12 -0600] "GET /2vdRlQeu.mediawiki HTTP/1.1" 404 487 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
```

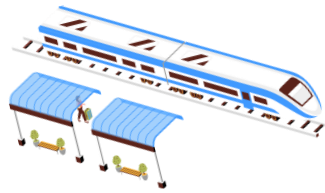
The event details are in ***a clearly readable format***

[illegible]

**k.z**



# Passive security monitoring : techniques



The same event log in  
**Windows' native Event Viewer**  
*things are a lot clearer !*

The screenshot displays the Windows Event Viewer interface. On the left, the 'Event Viewer (Local)' tree shows 'Custom Views', 'Windows Logs', 'Applications and Services Logs', 'Saved Logs', and 'Subscriptions'. The 'Saved Logs' folder is expanded, showing a log named 'mimikatz-privesc-hashdump'. The main pane shows a list of 13 events from this log. The events are all 'Information' level, occurring on 4/30/2019. The sources are 'Microsoft Windows security auditing' and 'Eventlog'. The event IDs are 4798, 4673, and 1102. The task categories are 'User Account Management', 'Sensitive Privilege Use', and 'Log clear'.

| Level       | Date and Time         | Source             | Event ID | Task Category           |
|-------------|-----------------------|--------------------|----------|-------------------------|
| Information | 4/30/2019 12:10:56 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:10:43 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:10:41 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:10:08 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:09:39 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:09:39 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:09:39 PM | Microsoft Windo... | 4673     | Sensitive Privilege Use |
| Information | 4/30/2019 12:09:15 PM | Microsoft Windo... | 4798     | User Account Management |
| Information | 4/30/2019 12:08:29 PM | Microsoft Windo... | 4673     | Sensitive Privilege Use |
| Information | 4/30/2019 12:08:29 PM | Microsoft Windo... | 4673     | Sensitive Privilege Use |
| Information | 4/30/2019 12:08:29 PM | Microsoft Windo... | 4673     | Sensitive Privilege Use |
| Information | 4/30/2019 12:08:29 PM | Microsoft Windo... | 4673     | Sensitive Privilege Use |
| Information | 4/30/2019 12:08:22 PM | Eventlog           | 1102     | Log clear               |

The detailed view of event 4798, 'Microsoft Windows security auditing', is shown below. It includes a 'General' tab and a 'Details' tab. The 'Details' tab shows the following information:

A user's local group membership was enumerated.

Subject:

- Security ID: S-1-5-21-2977773840-2930198165-1551093962-1000
- Account Name: Sec504
- Account Domain: SEC504STUDENT
- Logon ID: 0x1E442

User:

- Security ID: S-1-5-21-2977773840-2930198165-1551093962-1000
- Account Name: Sec504
- Account Domain: SEC504STUDENT

Process Information:

- Process ID: 0xdcc
- Process Name: C:\Windows\explorer.exe

Log Name: Security

Source: Microsoft Windows security

Event ID: 4798

Level: Information

User: N/A

OpCode: Info

More Information: [Event Log Online Help](#)

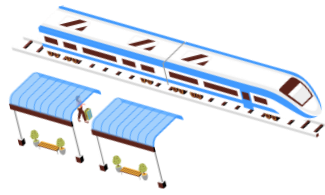
Logged: 4/30/2019 12:10:56 PM

Task Category: User Account Management

Keywords: Audit Success

Computer: Sec504Student

# Passive security monitoring : techniques



## Collection and **correlation** of event logs

- Consolidating all event logs into a single repository
- Simplifying data search and correlation across multiple sources
- Establishing the capability to identify relationships between systems/sources
- Formatting and standardizing data and information within event logs

→ But there is a challenge !



# Passive security monitoring : techniques

## Collection and **correlation** of event logs

### Apache log

```
"process": "357", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "251", "filename": "/usr/share/httpd/icons/apache_pb2.gif", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/icons/apache_pb2.gif", "query": "", "method":  
"process": "347", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "258", "filename": "/usr/share/httpd/icons/apache_pb2.gif", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/icons/apache_pb2.gif", "query": "", "method":  
"process": "357", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "92.118.161.37", "host": "ip-10-0-10-158.eu-west-1.compute.internal", "request": "/", "query": "", "meth  
"process": "338", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "213.92.193.38", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "355", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "69.162.124.102", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",
```

### Linux auth log

```
sshd[2519]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.11.1  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2
```

***What do you notice ?***



# Passive security monitoring : techniques

## Collection and **correlation** of event logs

### Apache log (**remoteIP**)

```
"process": "357", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "251", "filename": "/usr/share/httpd/icons/apache_pb2.gif", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/icons/apache_pb2.gif", "query": "", "method":  
"process": "347", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "258", "filename": "/usr/share/httpd/icons/apache_pb2.gif", "remoteIP": "54.240.197.230", "host": "34.250.27.141", "request": "/icons/apache_pb2.gif", "query": "", "method":  
"process": "357", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "92.118.161.37", "host": "ip-10-0-10-158.eu-west-1.compute.internal", "request": "/", "query": "", "meth  
"process": "338", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "213.92.193.38", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",  
"process": "355", "filename": "/usr/share/httpd/noindex/index.html", "remoteIP": "69.162.124.102", "host": "34.250.27.141", "request": "/", "query": "", "method": "GET", "status": "403",
```

### Linux auth log (**rhost**)

```
sshd[2519]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.11.1  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2  
sshd[2519]: Failed password for pac from 192.168.11.1 port 53949 ssh2
```

You can see that several fields in the events contain the same type of information, but the indicator name varies → **Source IP address**





# Passive security monitoring : techniques

---

## Collection and **correlation** of event logs

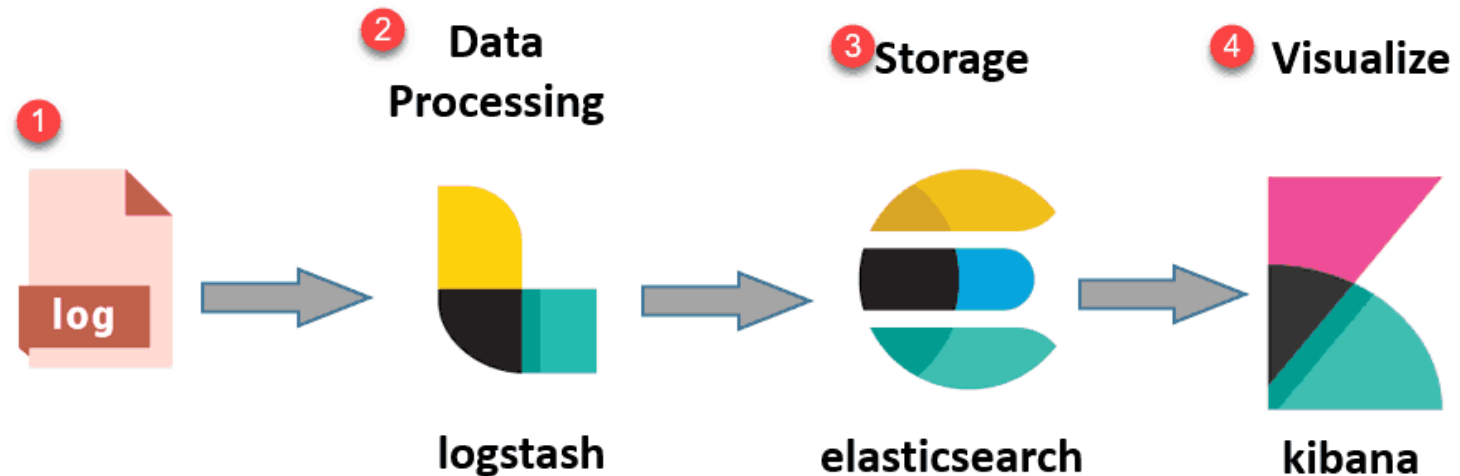
- **ELK** is an extremely popular log management and log analysis and can probably be considered as a de-facto industry standard for operational use cases.
- It is an acronym for three open source projects: **Elasticsearch, Logstash, and Kibana.**



# Passive security monitoring : techniques

## Collection and **correlation** of event logs

- **Elasticsearch** is a search and analytics engine. This is the part that allows the storing, indexing, querying, and analyzing of ingested data.
- **Logstash** is a server-side data processing pipeline solution that can ingest data from multiple sources simultaneously.
- **Kibana** is the frontend that lets users visualize data with charts and graphs for data that is stashed in Elasticsearch.



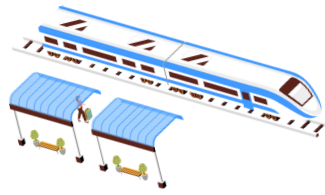


# Passive security monitoring : techniques

---

- Forms of passive security monitoring include the following:
- Network packet sniffing for the detection of malicious activity
- The collection and correlation of event logs to identify malicious behavior/activity
- **Host-based security solution agents collecting system statistics to discover malicious activities**

# Passive security monitoring : techniques



## Host-based agents

- An agent is an application installed on endpoint systems for monitoring and gathering relevant information.
- Its primary role is to periodically collect data or monitor activities on the system and transmit findings to a central server.
- Various security vendors offer agent technology with different capabilities, sizes, and footprints.

**wazuh.**

- One such tool is **Wazuh**, an **open-source** security monitoring platform designed for threat detection, integrity monitoring, and security analytics.
- It provides an extensive set of features for threat detection, compliance management, and incident response.



# Types of security monitoring

---

3 main types :

- Passive security monitoring
- **Active security monitoring**
- Threat hunting



# Active security monitoring

- Active security monitoring is aimed at **actively interrogating** the monitored environment for security incidents and other relevant security-related information.
- Some forms of active security monitoring include the following:
  - **Network scanning** to interrogate and examine network-connected devices
  - **Host-based agents** that can scan the host for security-related issues and malicious content
  - **Manually examining** endpoints for signs of malicious activity and content



# Active security monitoring

- Network scanning

**Network sniffing** involves **intercepting and analyzing** network traffic to capture data packets as they traverse a network.

Example of tools: Wireshark, tcpdump

While

**Network scanning** involves **probing** a network to discover active hosts, open ports, and services running on those hosts

**Scanners send packets to target hosts and analyze responses.**



# Active security monitoring

## Network scanning: IP and port scanning

- Systems communicate over networks using **Internet Protocol (IP) addresses**.
- Applications on a system use **IP addresses and port numbers (TCP or UDP) to create sockets for communication**. An IP address is analogous to the street address of an apartment complex.
- Systems use **IP addresses and port numbers together** to communicate effectively over a network.





# Active security monitoring

## Network scanning: IP and port scanning

- Systems use **IP addresses and port numbers together** to communicate effectively over a network.
- Knowing what IP addresses are **live (present and running)** on your network is valuable information for figuring out all **your assets**
- Figuring out what port numbers are **open (respond to network requests)** can give us information about the applications or services running on that live system.

***Can you think of a tool we used in our Pentesting workshop ?***



# Active security monitoring

## Network scanning: IP and port scanning

- Systems use **IP addresses and port numbers together** to communicate effectively over a network.
- Knowing what IP addresses are **live (present and running)** on your network is valuable information for figuring out all **your assets**
- Figuring out what port numbers are **open (respond to network requests)** can give us information about the applications or services running on that live system.
- **Nmap** (<https://nmap.org/>)
- Angry port scanner (<https://angryip.org/>)
- Netcat (<http://netcat.sourceforge.net/>)



# Active security monitoring

## Network scanning: network mapping

- It is focused on **discovering the topology** of a network.
- Typically, this involves mapping out devices connected to network switches by querying those switches using Simple Network Management Protocol (SNMP).
- Other methods may also be used for this purpose:
- Zenmap (<https://nmap.org>)
- SolarWinds network topology mapper (<https://www.solarwinds.com/network-topology-mapper>)
- Spiceworks Network Mapping Tool (<https://www.spiceworks.com/freenetwork-mapping-software/>)



# Active security monitoring

---

Host-based agents

Again, like Wazuh !

Not all ICS equipment can run security monitoring agents because of resource restraints, missing **operating system (OS)** capabilities (there might not be a fitting agent for that ancient/specialty OS), or because the **Original Equipment Manufacturer (OEM)** does not allow agents to be installed.

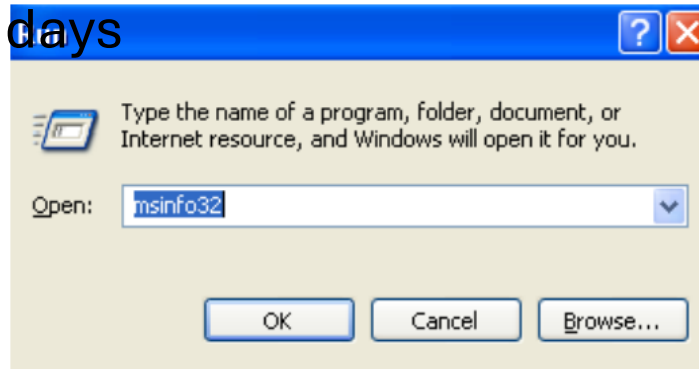


# Active security monitoring

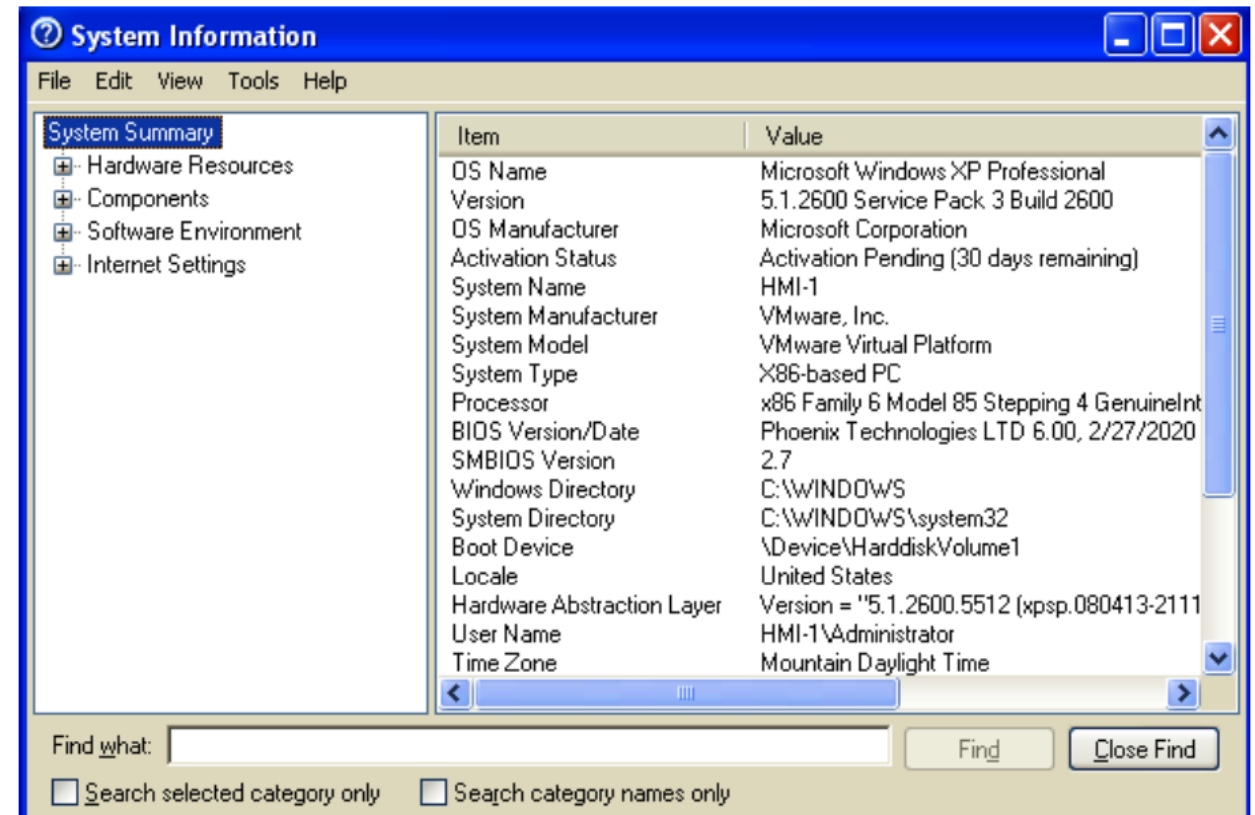
- **Manually examining** : Example **Manually inspecting an industrial computer**

Msinfo32, built into Windows OSes since the Windows XP

days



As you can see, the System Information tool has sections on **Hardware**, **Software**, **Components**, and **Internet Settings**. You can click through and browse all the subsections and even search for certain information.





# Types of security monitoring

3 main types :

- Passive security monitoring
- Active security monitoring

- Between the techniques and tools we discussed until now, we have captured a boatload of security-related information.
- let's look at a very specific usage of those tools and the security-related information we collected :

- **Threat hunting**



# Threats hunting

- At its core, it is all about **hypothesizing a risk** or threat scenario and proving or disproving the presence of that threat scenario within our environment with **threat hunting exercises**.

*A hypothetical threat scenario could be a competitor has infiltrated our networks and is now stealing our proprietary information.*

- A fitting threat hunting exercise that **proves or disproves** this hypothesized threat scenario could include activities such as:
  - PLC/HMI and safety system log reviews,
  - firewall log reviews, Windows Event log reviews,
  - network packet captures, public record investigations
  - *Anything that could show proof of the hypothesized threat being actualized in the environment*



# Threats hunting

---

- Let's take an example:

*we found a system on our network trying to communicate with an IP address, 61.188.18.25,  
and found this suspicious for one reason or the other*

- We can use an online IP reputation service such as **GreyNoise** (<https://greynoise.io>) to see what is known about this IP address :





# Threats hunting

- we can see that the IP address is part of a **trickbot campaign**



Enter GNQL query...

GREYNOISE

Malicious ISP

61.188.18.25

Organization: CHINANET-BACKBONE  
Actor: Unknown

This IP address has been opportunistically scanning the Internet, and has completed a full TCP connection. Reported activity could not be spoofed.

< TLS/SSL Crawler < TrickBot < Web Crawler

This IP address has been observed by GreyNoise scanning the Internet on the following ports:

|      |                 |
|------|-----------------|
| Scan | Port / Protocol |
|      | 8000 / TCP      |
|      | 8080 / TCP      |

Web

Paths

/manager/html

User-Agents

User-Agent:Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.2; .NET CLR 1.0.3705

JAS

Fingerprint / Port

6734f37431670b3ab4292b8f60f29984 / 8000

This IP is not probing for any known CVEs

Tags

< TLS/SSL Crawler

Category: Activity

This IP address has been observed attempting to opportunistically crawl the Internet and establish TLS/SSL connections.

< TrickBot

Category: Worm

This IP address exhibits behavior that indicates it is infected with the banking malware TrickBot.

References:

https://blog.malwarebytes.com/detection

5

< Web Crawler

Category: Activity

This IP address has been seen crawling HTTP(S) servers around the Internet.

04/03/2026

Cyber-security in Industrial Control Systems

41

k.z



# Threats hunting

- What is needed to perform threat hunting exercises?

The short answer to this question is **information** – information about your assets, the network connections that traverse between your assets, and the interactions users have with your assets.

- Network traffic logs
- Endpoint OS and application event logs
- Tracking new and changed devices on the (industrial) network
- Network services event logs



# Threats hunting

- Threat Hunt Scenario – Suspicious External Connections

The environment we are going to perform threat hunting activities on is unfamiliar or new to us. Our company purchased a new production plant with an existing ICS network infrastructure they are looking to tie to the existing company infrastructure, and we want to make sure that it is safe to do so.

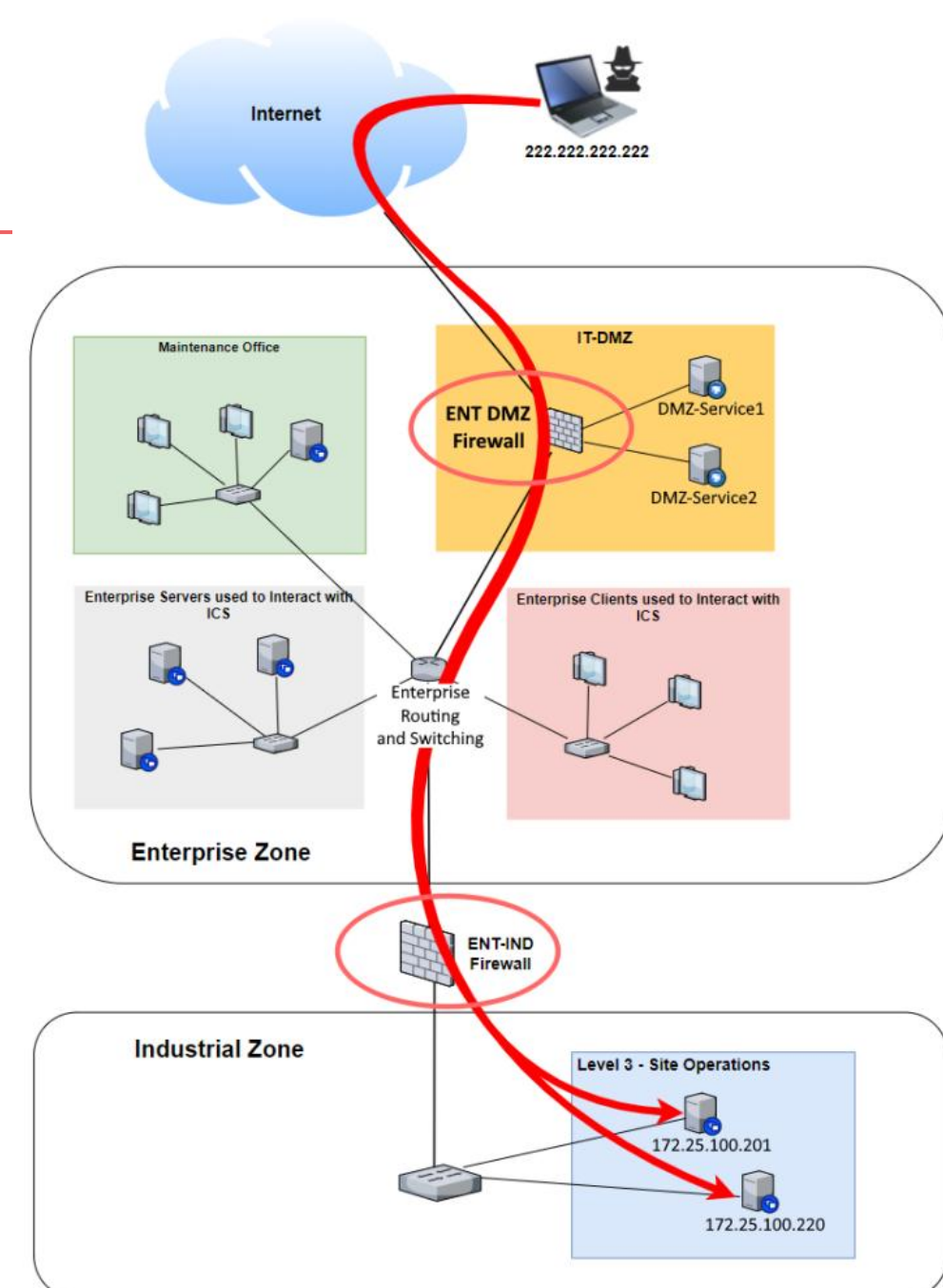
→ Building on the convenient fact that **there should not be many connections** into the industrial network from external networks, we are going to see if we can prove or disprove the hypothesis **there are suspicious external connections going into the industrial environment** by searching for some common indicators that set apart the malicious connections from legitimate ones.



# Threats hunting

## Threat Hunt Scenario – Suspicious External Connections

- We should start our threat hunting investigations by looking into ***ingress connections***.

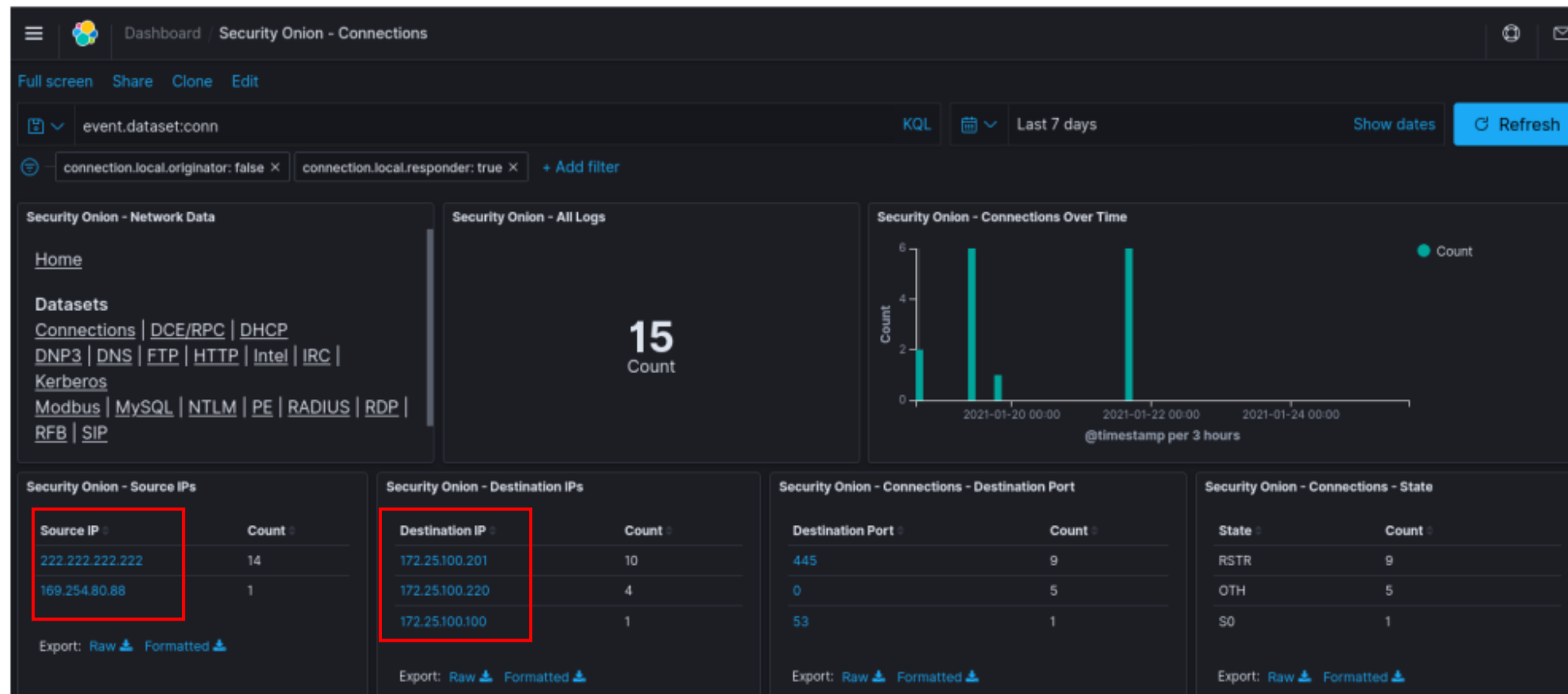




# Threats hunting

## Threat Hunt Scenario – Suspicious External Connections

- To do this, we will look at connections originating from outside the organization





# Threats hunting

## Threat Hunt Scenario – Suspicious External Connections

- We should start our threat hunting investigations by looking into ***ingress connections***.
- The connections were made over **ports 445 – Server Message Block (SMB)** and **0 – Internet Connection Management Protocol (ICMP) echo or PING**.

| Security Onion - Source IPs |       | Security Onion - Destination IPs |       | Security Onion - Connections - Destination Port |       |
|-----------------------------|-------|----------------------------------|-------|-------------------------------------------------|-------|
| Source IP                   | Count | Destination IP                   | Count | Destination Port                                | Count |
| 222.222.222.222             | 14    | 172.25.100.201                   | 10    | 445                                             | 9     |
|                             |       | 172.25.100.220                   | 4     | 0                                               | 5     |
| Export: Raw  Formatted      |       | Export: Raw  Formatted           |       | Export: Raw  Formatted                          |       |

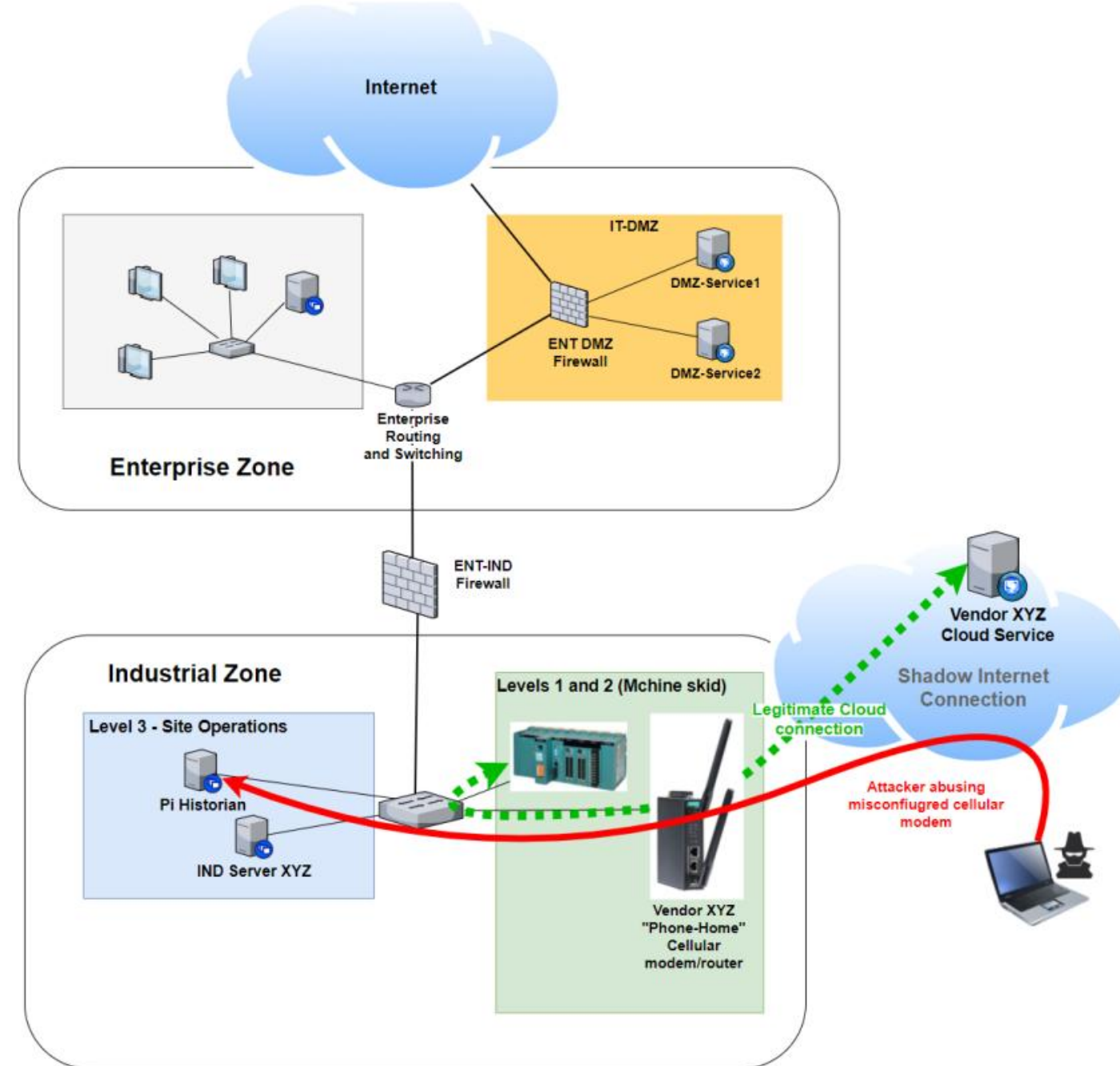


# Threats hunting

In this scenario, let's say a company installed a special kind of internet router, like the ones made by **Moxa**, to help their equipment connect to an online service the company owns.

If the setup doesn't properly restrict access from the internet, or the cellular device used has a vulnerability

→ direct access from the internet into anything that is accessible by the vendor's solution







# Threats hunting

- Farfetched ? Think again !

Every result that is returned here is a direct connection to the internal (ICS) network of the organization.

-- *Internet-exposed Rockwell Automation PLC network cards*

## TOTAL RESULTS

307

## TOP COUNTRIES



|               |     |
|---------------|-----|
| United States | 178 |
| Canada        | 45  |
| Egypt         | 19  |
| Hong Kong     | 9   |
| China         | 8   |

## TOP SERVICES

|             |     |
|-------------|-----|
| EtherNet/IP | 271 |
| SNMP        | 26  |
| SSH         | 7   |
| POP3        | 1   |
| 830         | 1   |

## TOP ORGANIZATIONS

|                  |     |
|------------------|-----|
| Verizon Wireless | 101 |
| TE Data          | 19  |
| AT&T Wireless    | 14  |
| Bell Canada      | 14  |
| Krakr1901        | 10  |

## TOP OPERATING SYSTEMS

|        |   |
|--------|---|
| Debian | 1 |
| Ubuntu | 1 |

## TOP PRODUCTS

|                                   |     |
|-----------------------------------|-----|
| Rockwell Automation/Allen-Bradley | 161 |
| OpenSSH                           | 6   |

**New Service:** Keep track of what you have connected to the Internet. Check out **Shodan Monitor**

**209.147.121.46**

Isomedia  
Added on 2021-01-25 18:06:14 GMT  
United States, Bonney Lake

Product name: 1756-ENBT/D  
Vendor ID: Rockwell Automation/Allen-Bradley  
Serial number: 0x00dde8b4  
Device type: Communications Adapter  
Device IP: 192.168.10.10

**176.202.160.234**

Ooredoo Qatar  
Added on 2021-01-25 18:52:52 GMT  
Qatar

Product name: 1768-ENBT/A  
Vendor ID: Rockwell Automation/Allen-Bradley  
Serial number: 0x403dcfb4  
Device type: Communications Adapter  
Device IP: 192.10.0.2

**190.217.5.123**

Level 3 Communications  
Added on 2021-01-25 17:34:42 GMT  
Venezuela, Caracas

Product name: 1756-ENBT/A  
Vendor ID: Rockwell Automation/Allen-Bradley  
Serial number: 0x00921fc9  
Device type: Communications Adapter  
Device IP: 192.168.20.211

**166.157.134.28**

28.sub-166-157-134.myvzw.com  
Verizon Wireless  
Added on 2021-01-25 19:58:39 GMT  
United States

Product name: 1756-ENBT/A  
Vendor ID: Rockwell Automation/Allen-Bradley  
Serial number: 0x00bbd474  
Device type: Communications Adapter  
Device IP: 100.100.100.152

**96.1.49.20**

Telus Communications  
Added on 2021-01-25 17:40:58 GMT  
Canada, Spruce Grove

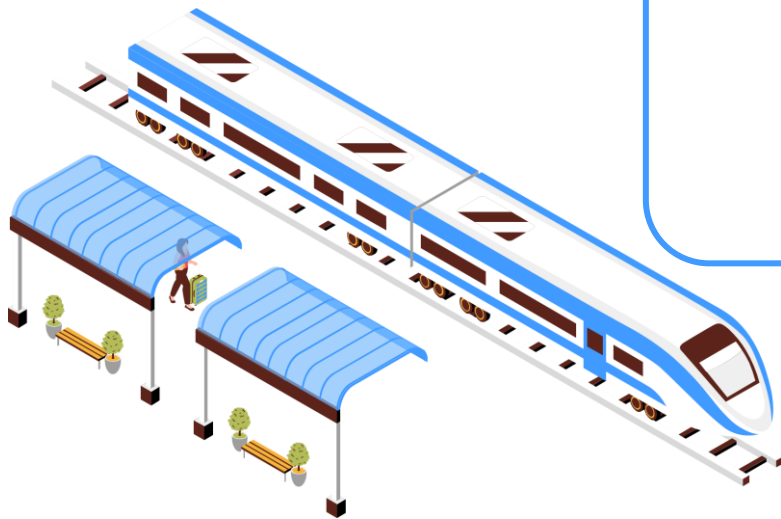
Product name: 1756-ENBT/A  
Vendor ID: Rockwell Automation/Allen-Bradley  
Serial number: 0x01065360  
Device type: Communications Adapter  
Device IP: 192.168.1.40





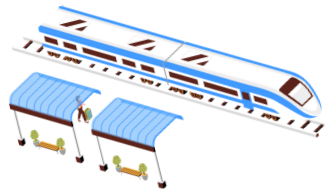
# Summary

- Throughout this lecture, we've explored various aspects of security monitoring specific to ICS environments.
- We've only scratched the surface of the many technologies, tools, activities, methodologies, and strategies available to help you assess the security of your ICS environment.
- The next steps are up to you !

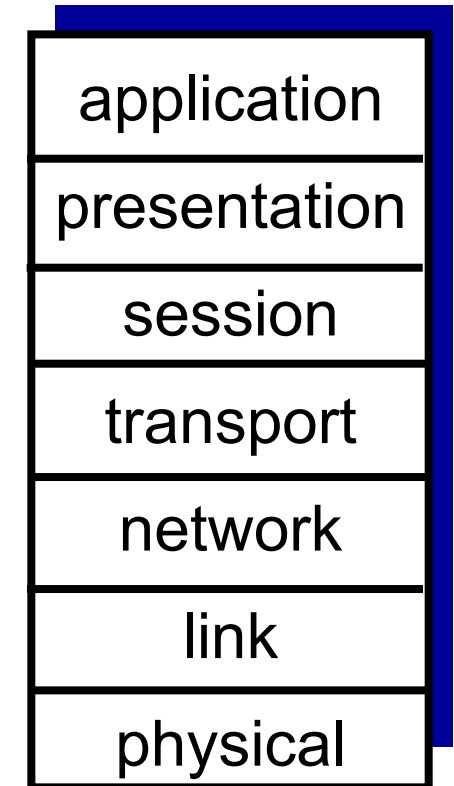


About our lab 😊

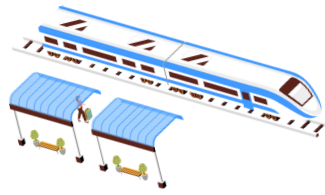
# Overview of the OSI Model



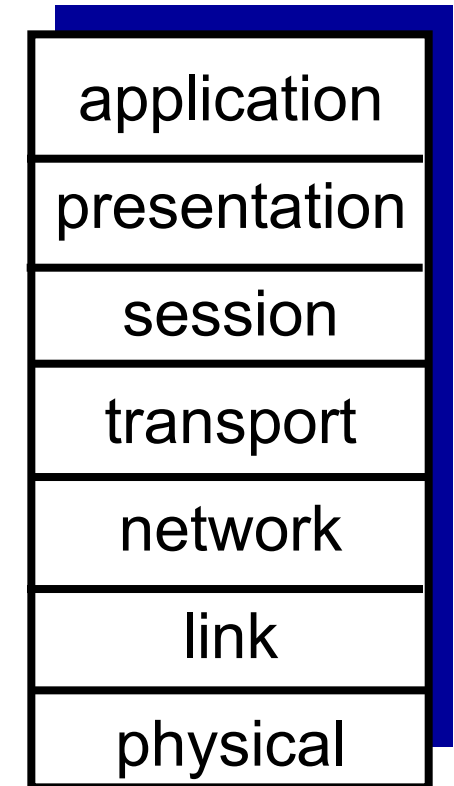
- **Open Systems Interconnection (OSI) Model** is a **layered network architecture** that describes communication between computers.
  - Divides networking into **7 functional layers**.
  - Each layer **performs specific tasks** and interacts only with adjacent layers.
  - Provides a **modular approach** to network design and troubleshooting.



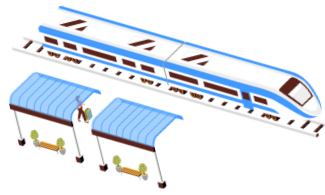
# Overview of the OSI Model



- **Open Systems Interconnection (OSI) Model** is a **layered network architecture** that describes communication between computers.
  - Divides networking into **7 functional layers**.
  - Each layer **performs specific tasks** and interacts only with adjacent layers.
  - Provides a **modular approach** to network design and troubleshooting.
- Helps diagnose network issues.
- Provides a standardized framework for hardware and software development.



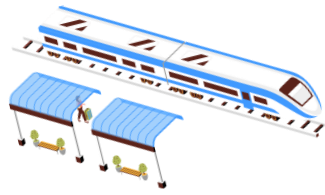
# Why do we need models ?



- **Historical Context:**
  - OSI Model was developed in the **1980s** but wasn't widely adopted due to complexity.
  - TCP/IP became the standard due to its adaptability and simplicity.
- **What are OSI and TCP/IP?**
  - **OSI Model:** A **theoretical framework** developed by ISO for understanding networking.
  - **TCP/IP Model:** A **practical implementation** used in real-world internet communication.

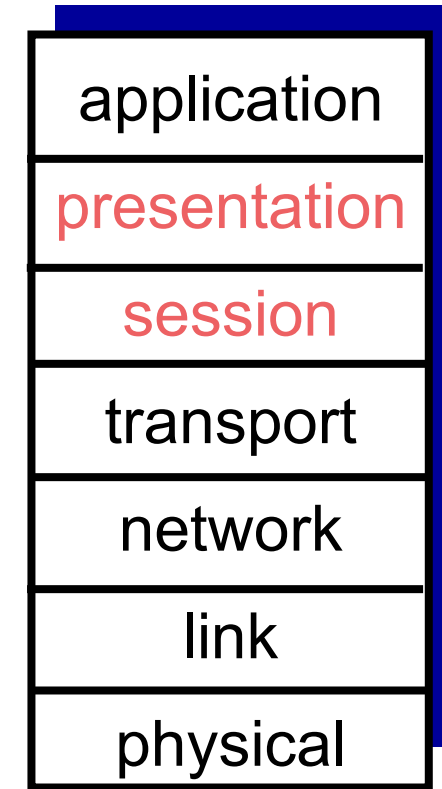
*ISO: International Organization for Standardization*

# ISO/OSI reference model



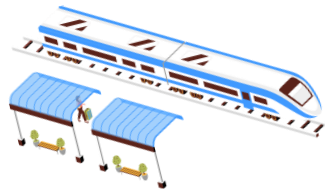
Two layers not found in Internet protocol stack!

- *presentation*: allow applications to interpret meaning of data, e.g., encryption, compression, machine-specific conventions
- *session*: synchronization, checkpointing, recovery of data exchange
- Internet stack “missing” these layers!
  - these services, *if needed*, must be implemented in application
  - needed?



The seven layer OSI/ISO reference model

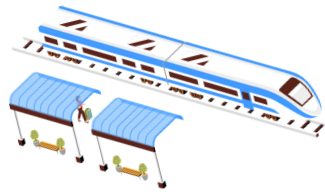
# Why layering?



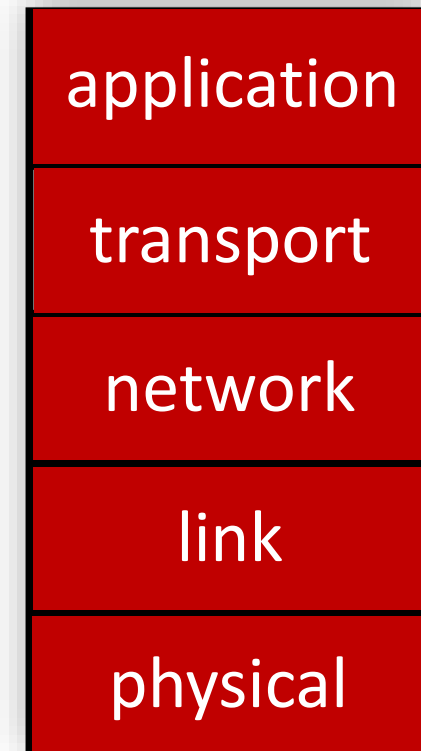
## Approach to designing/discussing complex systems:

- explicit structure allows identification, relationship of system's pieces
  - layered *reference model* for discussion
- modularization eases maintenance, updating of system
  - change in layer's service *implementation*: transparent to rest of system
  - e.g., change in gate procedure doesn't affect rest of system

# Layered Internet protocol stack

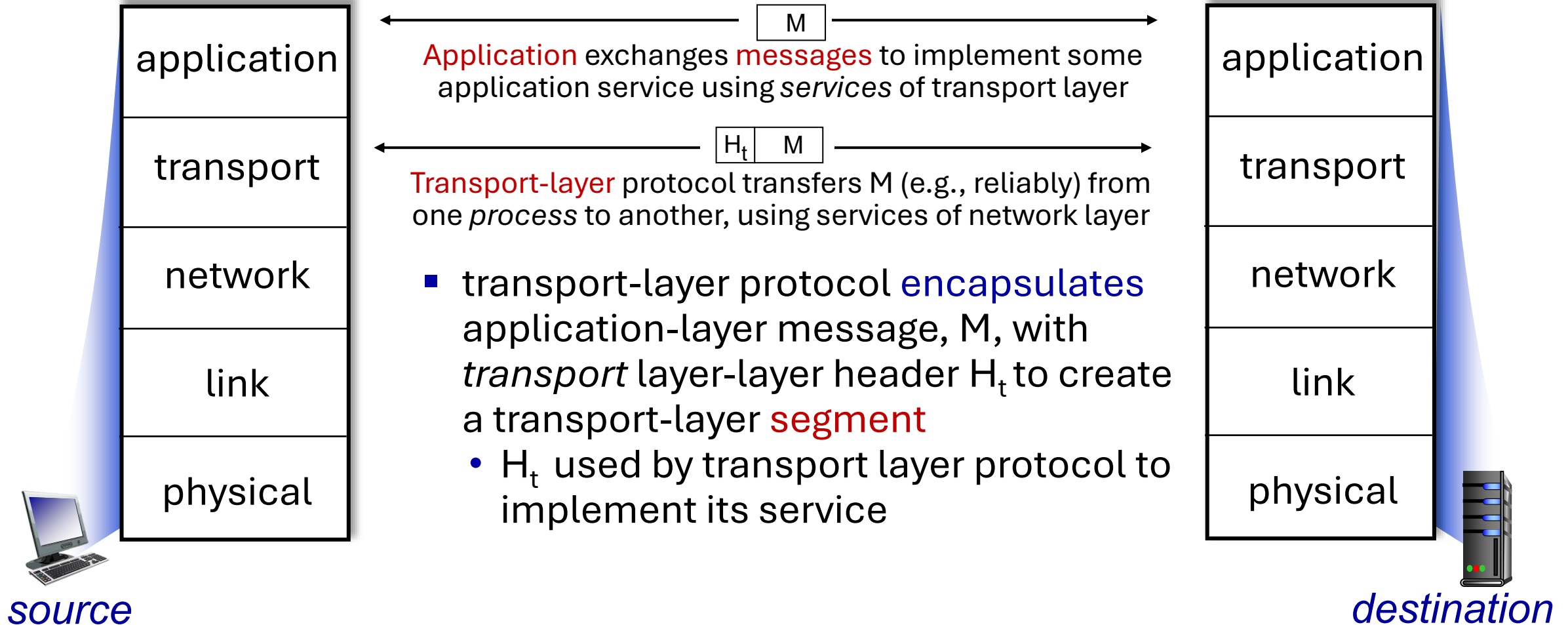
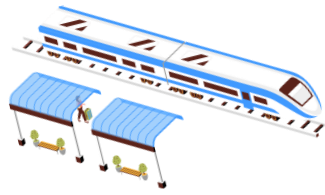


- *application*: supporting network applications
  - HTTP, IMAP, SMTP, DNS
- *transport*: process-process data transfer
  - TCP, UDP
- *network*: routing of datagrams from source to destination
  - IP, routing protocols
- *link*: data transfer between neighboring network elements
  - Ethernet, 802.11 (WiFi), PPP
- *physical*: bits “on the wire”

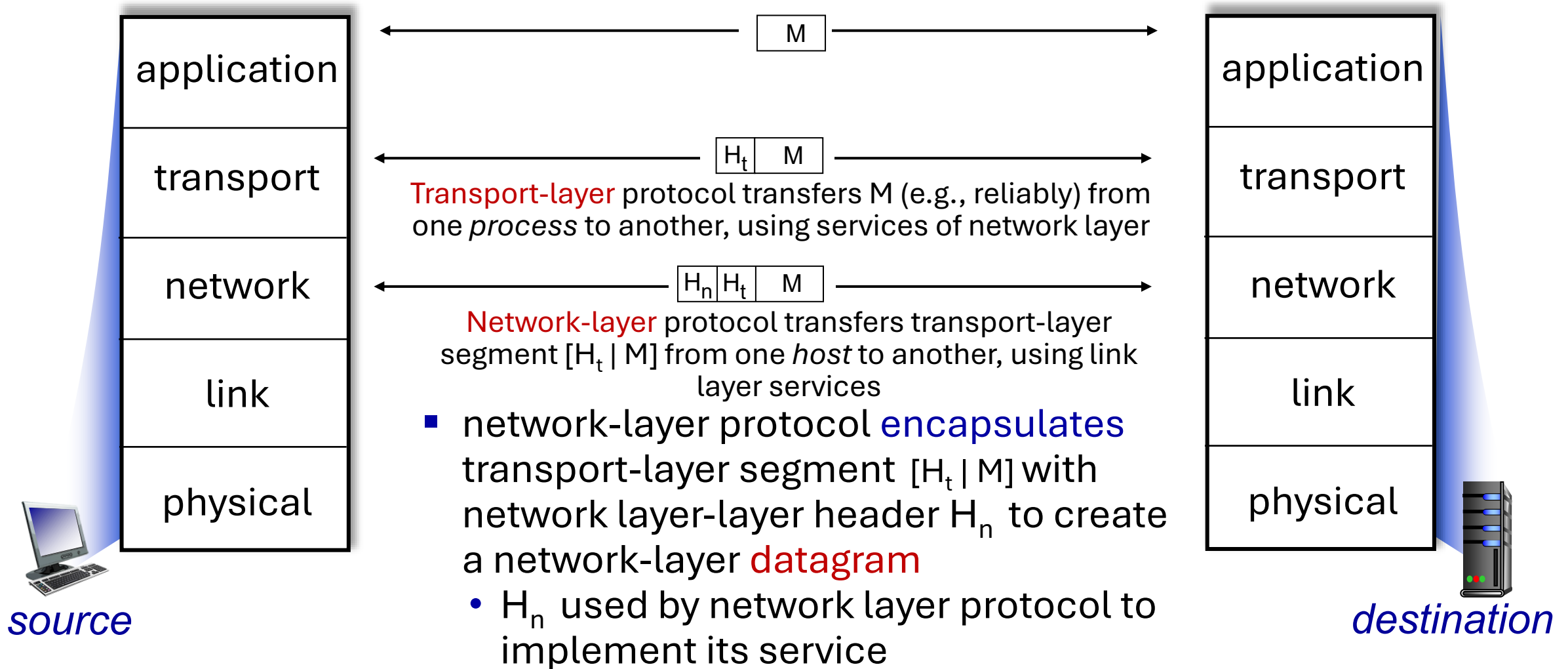
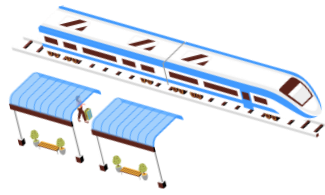




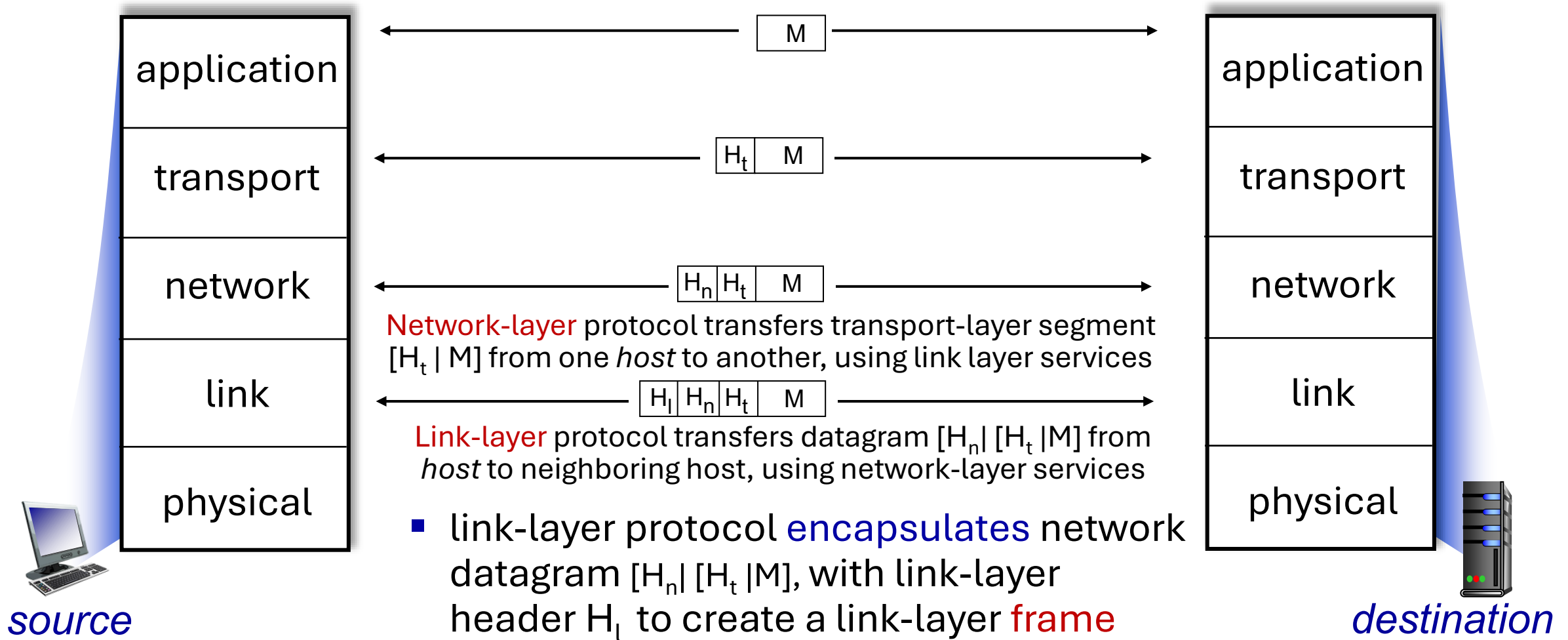
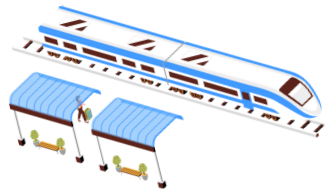
# Services, Layering and Encapsulation



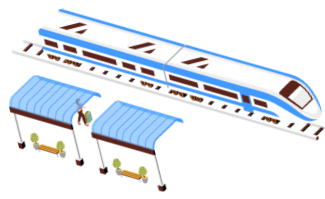
# Services, Layering and Encapsulation



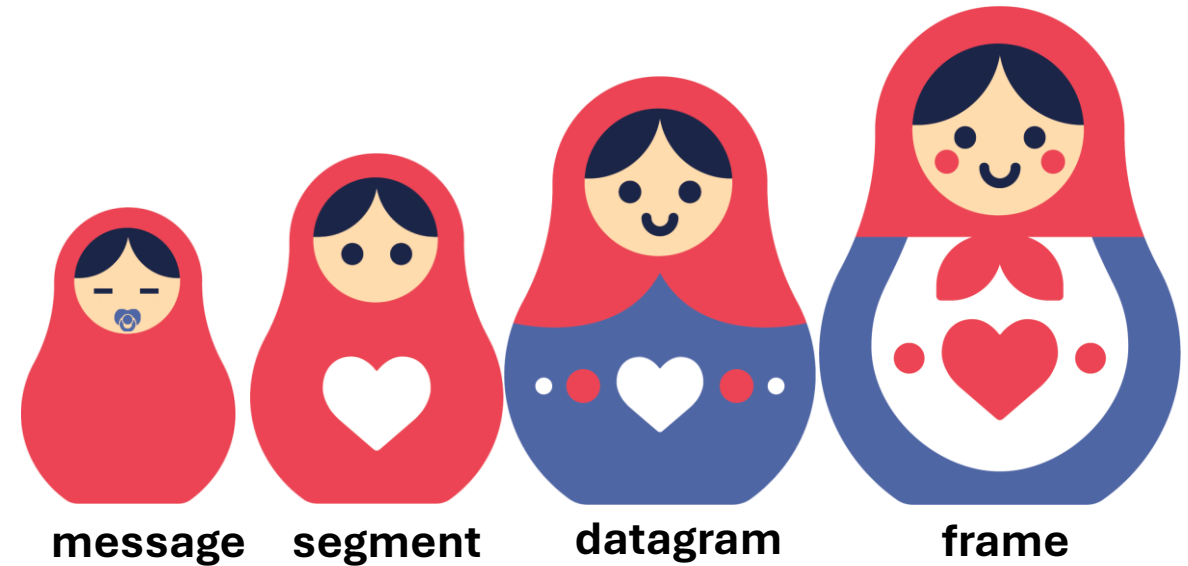
# Services, Layering and Encapsulation



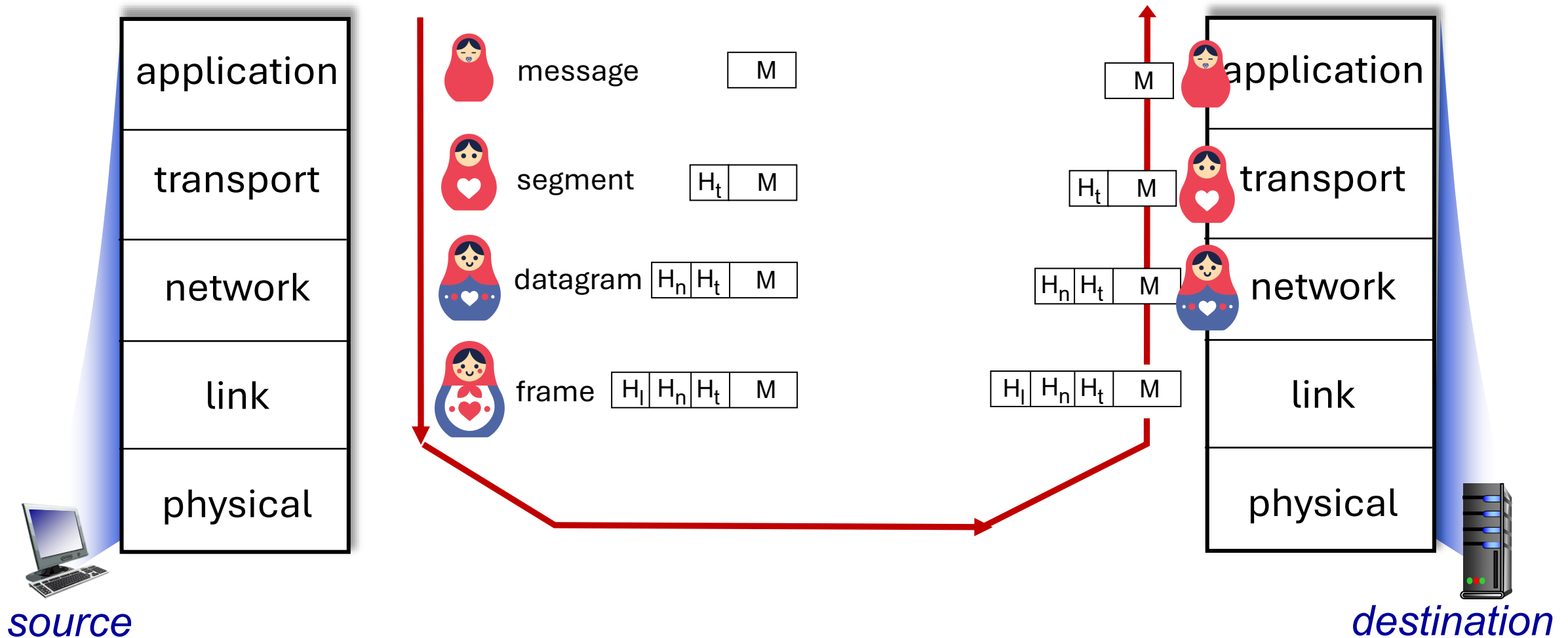
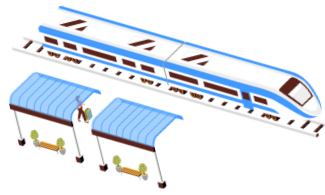
# Encapsulation



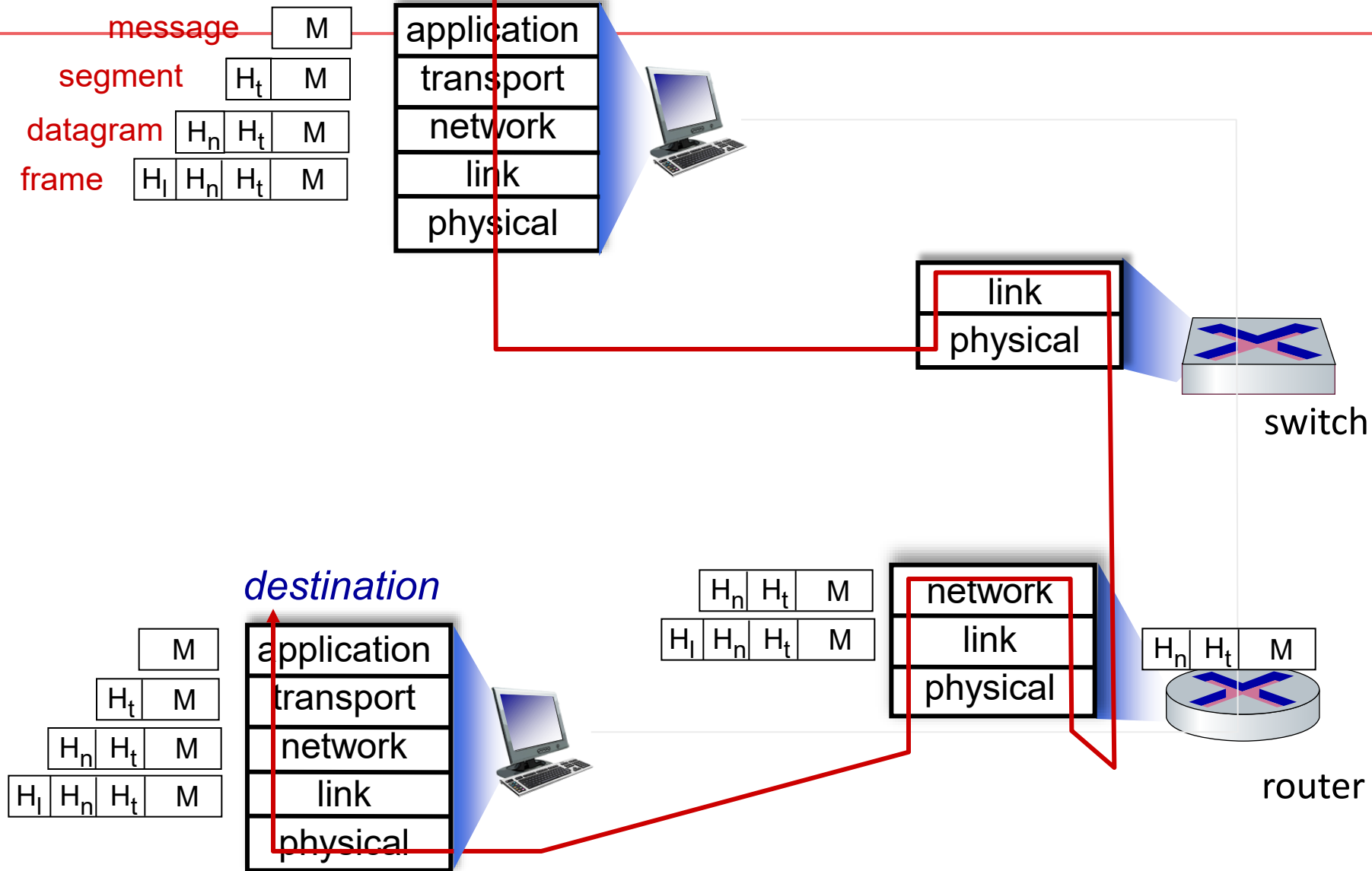
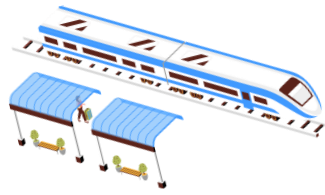
## *Matryoshka dolls (stacking dolls)*



# Services, Layering and Encapsulation



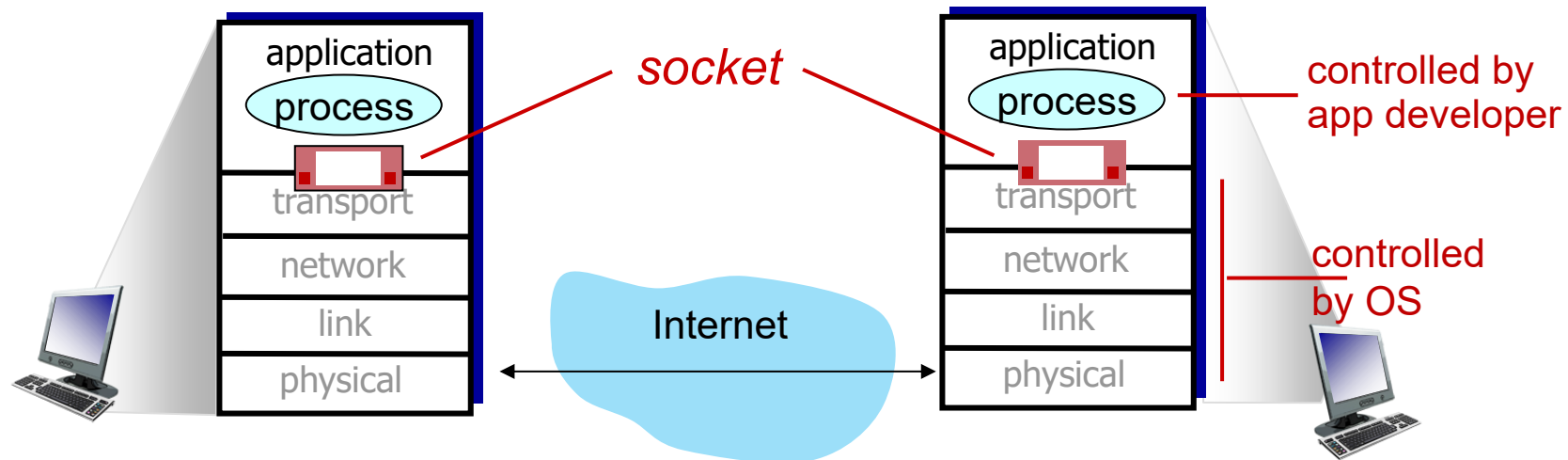
# Encapsulation: an end-end view





# Sockets

- process sends/receives messages to/from its **socket**
- socket analogous to door
  - sending process shoves message outdoor
  - sending process relies on transport infrastructure on other side of door to deliver message to socket at receiving process
  - two sockets involved: one on each side





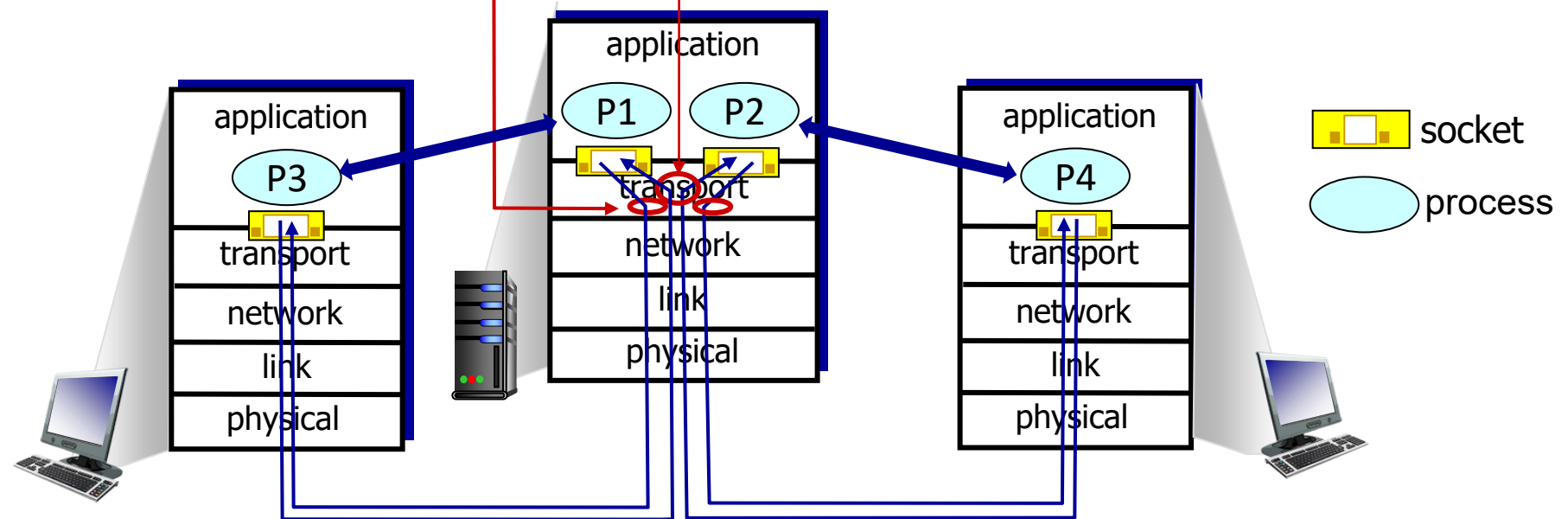
# Multiplexing/demultiplexing

## *multiplexing as sender:*

handle data from multiple sockets, add transport header (later used for demultiplexing)

## *demultiplexing as receiver:*

use header info to deliver received segments to correct socket

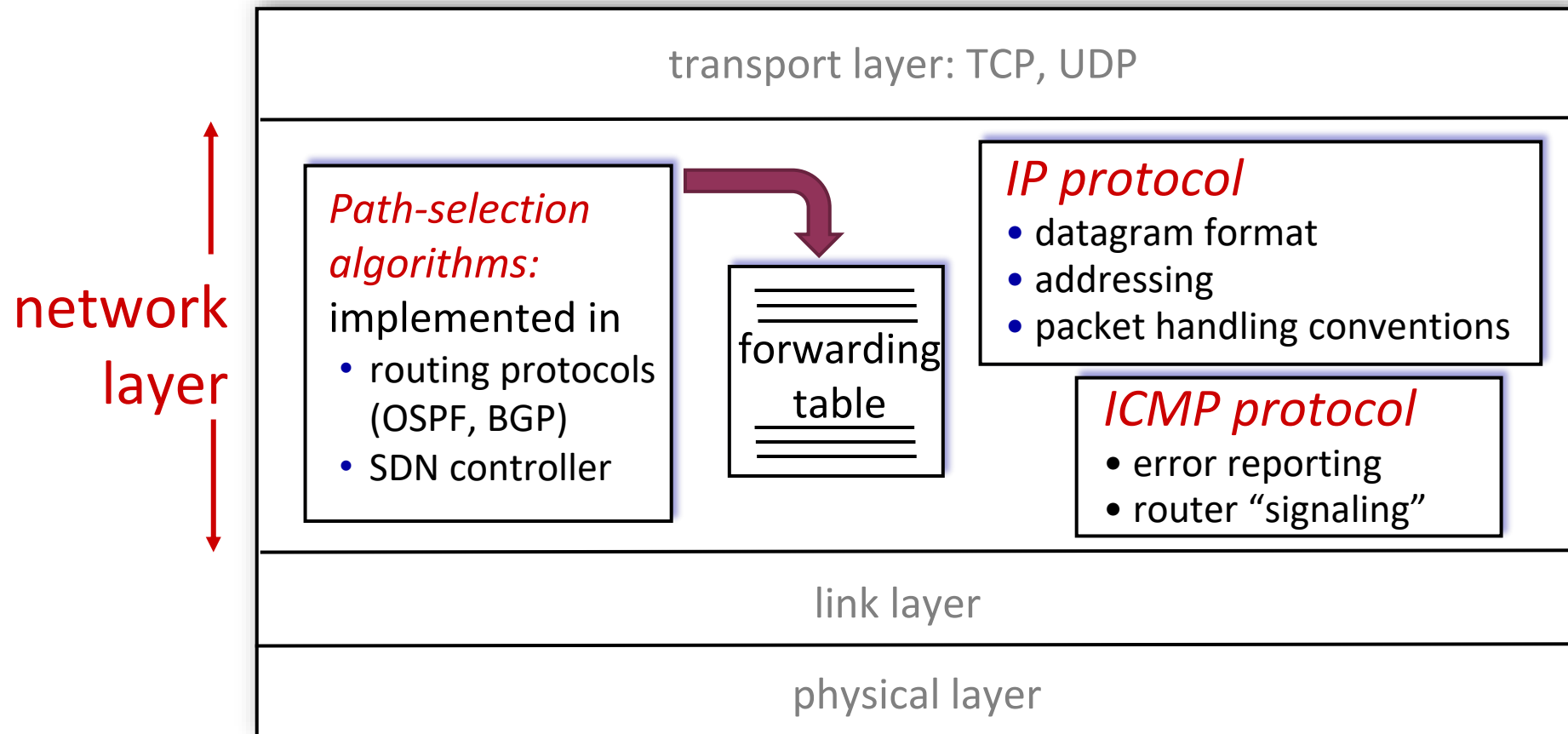






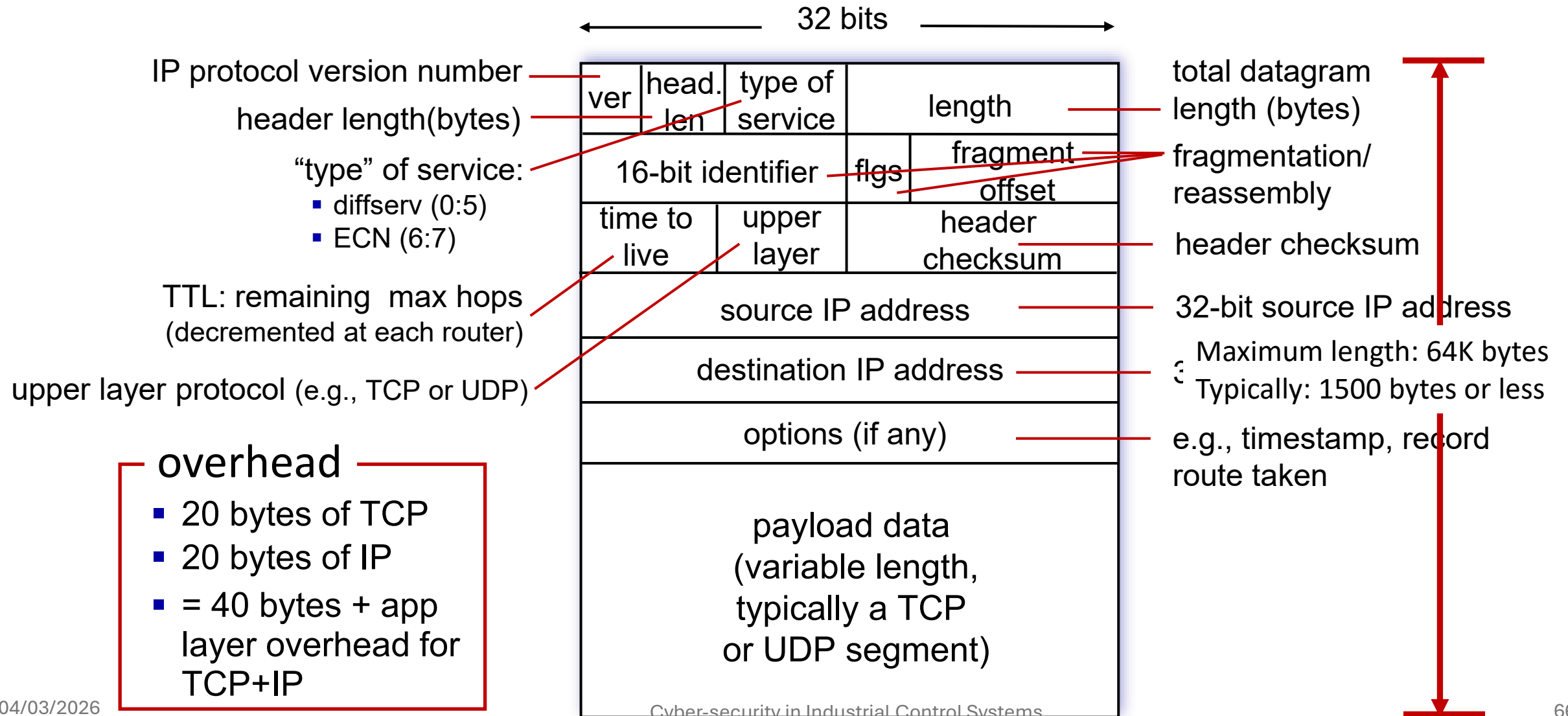
# Network Layer: Internet

host, router network layer functions:





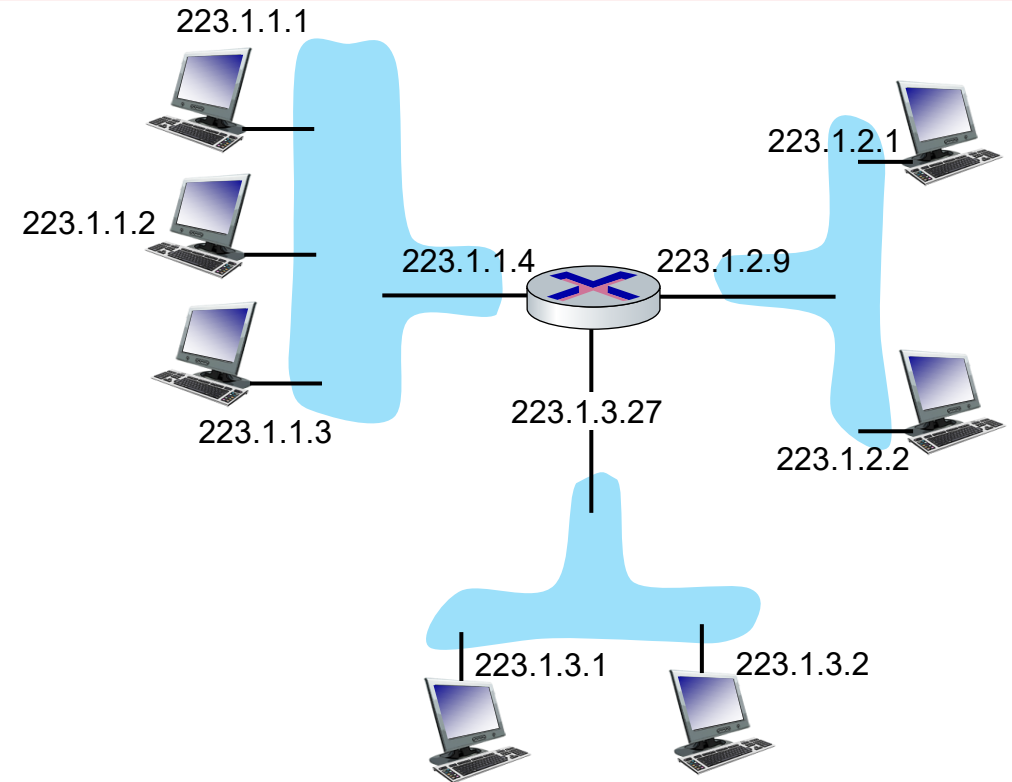
# IP Datagram format





# IP addressing: introduction

- **IP address:** 32-bit identifier associated with each host or router *interface*
- **interface:** connection between host/router and physical link
- router's typically have multiple interfaces
- host typically has one or two interfaces (e.g., wired Ethernet, wireless 802.11)



dotted-decimal IP address notation:

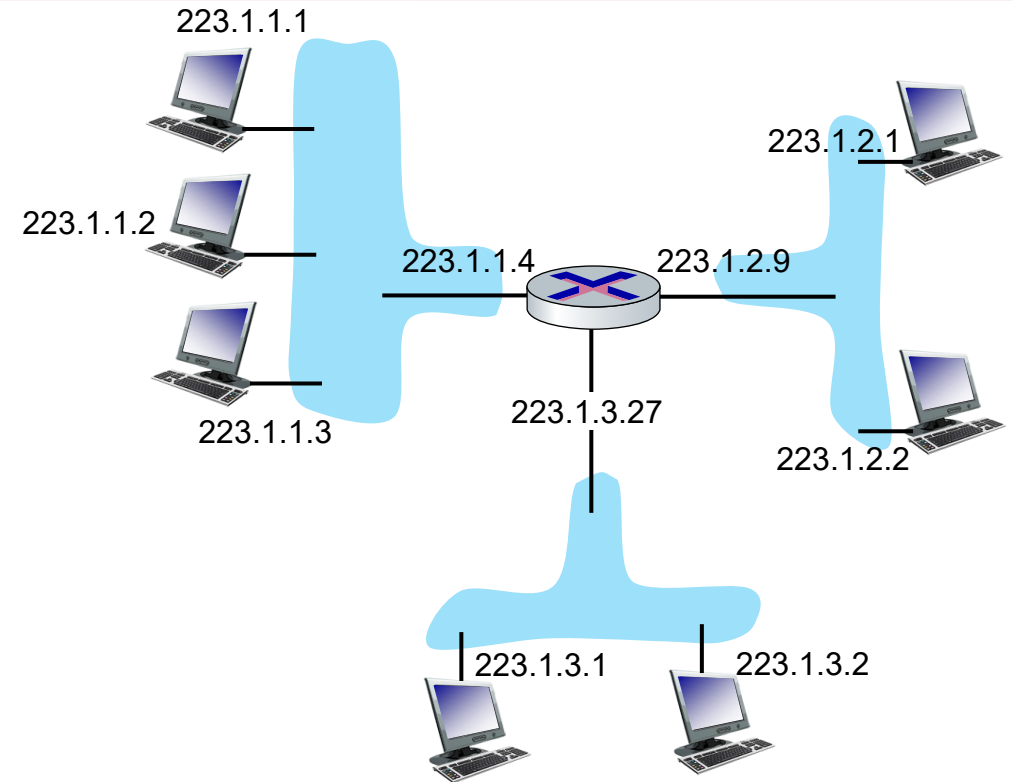
223.1.1.1 = 11011111 00000001 00000001 00000001

223                      1                      1                      1 Network Layer: 4-67



# IP addressing: introduction

- **IP address:** 32-bit identifier associated with each host or router *interface*
- **interface:** connection between host/router and physical link
- router's typically have multiple interfaces
- host typically has one or two interfaces (e.g., wired Ethernet, wireless 802.11)



dotted-decimal IP address notation:

223.1.1.1 = 11011111 00000001 00000001 00000001

223

1

1

1

68

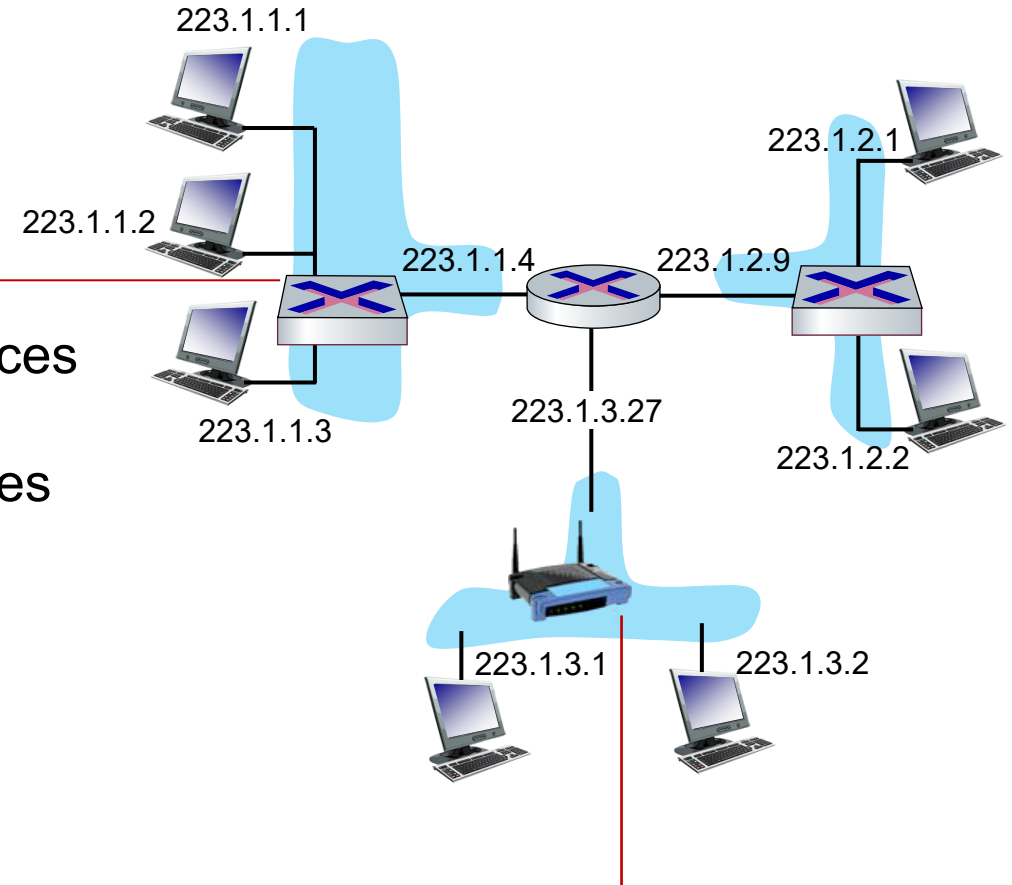


# IP addressing: introduction

**Q:** how are interfaces actually connected?

**A:** wired  
Ethernet interfaces  
connected by  
Ethernet switches

**For now:** don't need to worry  
about how one interface is  
connected to another (with no  
intervening router)

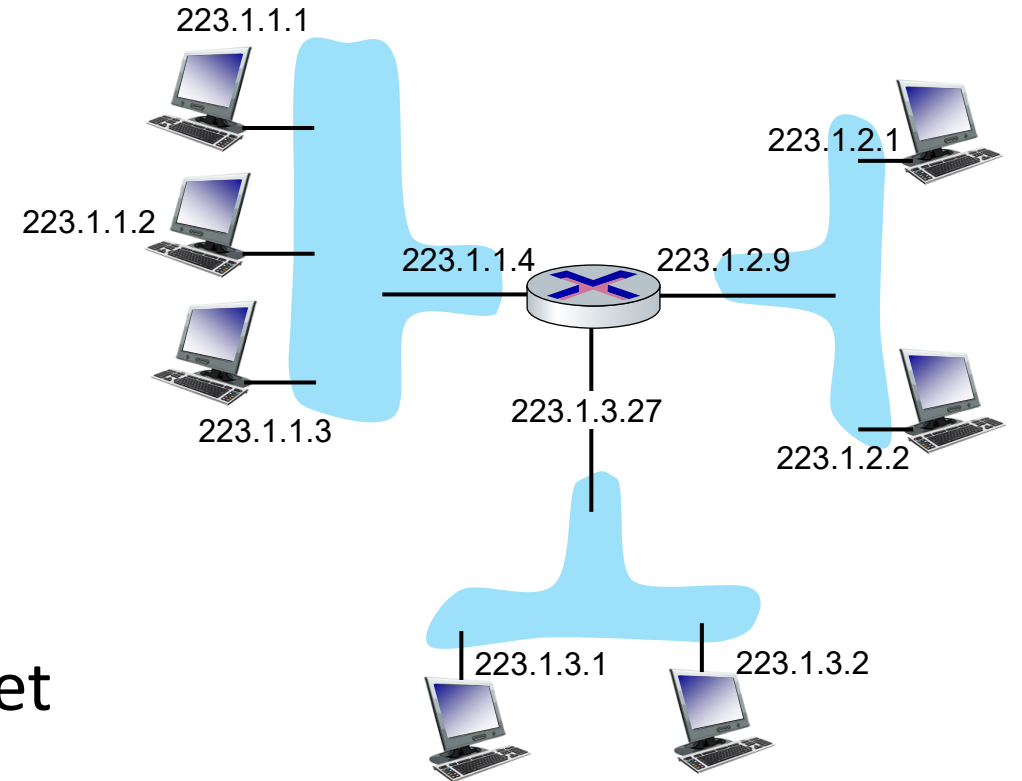


**A:** wireless WiFi interfaces  
connected by WiFi base station



# Subnets

- *What's a subnet ?*
  - device interfaces that can physically reach each other **without passing through an intervening router**
- IP addresses have structure:
  - **subnet part:** devices in same subnet have common high order bits
  - **host part: remaining** low order bits



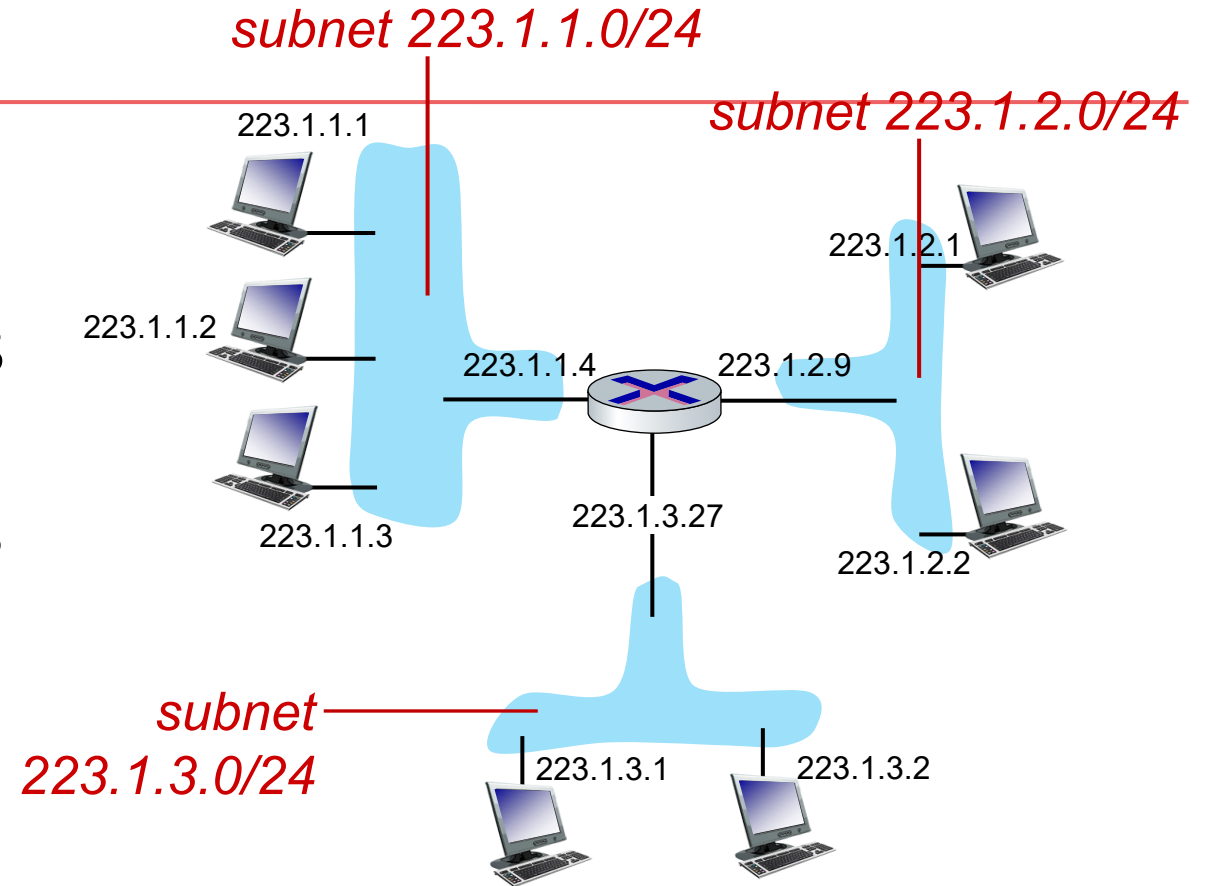
network consisting of 3 subnets



# Subnets

## *Recipe for defining subnets:*

- detach each interface from its host or router, creating “islands” of isolated networks
- each isolated network is called a *subnet*



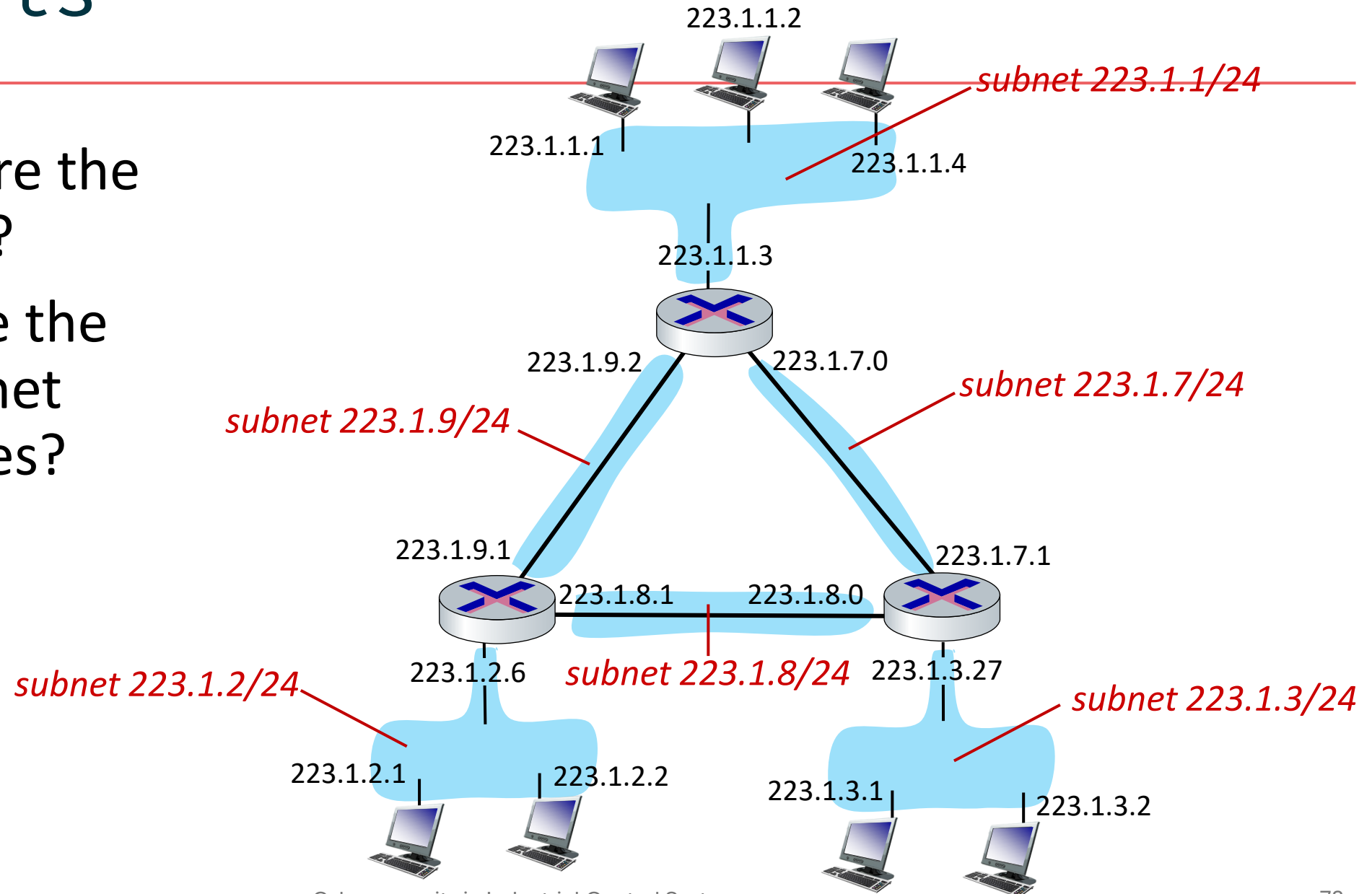
subnet mask: /24

(high-order 24 bits: subnet part of IP address)



# Subnets

- where are the subnets?
- what are the /24 subnet addresses?







# IP addresses: how to get one?

That's actually **two** questions:

1. Q: How does a *host* get IP address within its network (host part of address)?
2. Q: How does a *network* get IP address for itself (network part of address)?

How does *host* get IP address?

- hard-coded by sysadmin in config file (e.g., /etc/rc.config in UNIX)
- **DHCP**: **D**ynamic **H**ost **C**onfiguration **P**rotocol: dynamically get address from as server
  - “plug-and-play”



# DHCP: Dynamic Host Configuration Protocol

**goal:** host *dynamically* obtains IP address from network server when it “joins” network

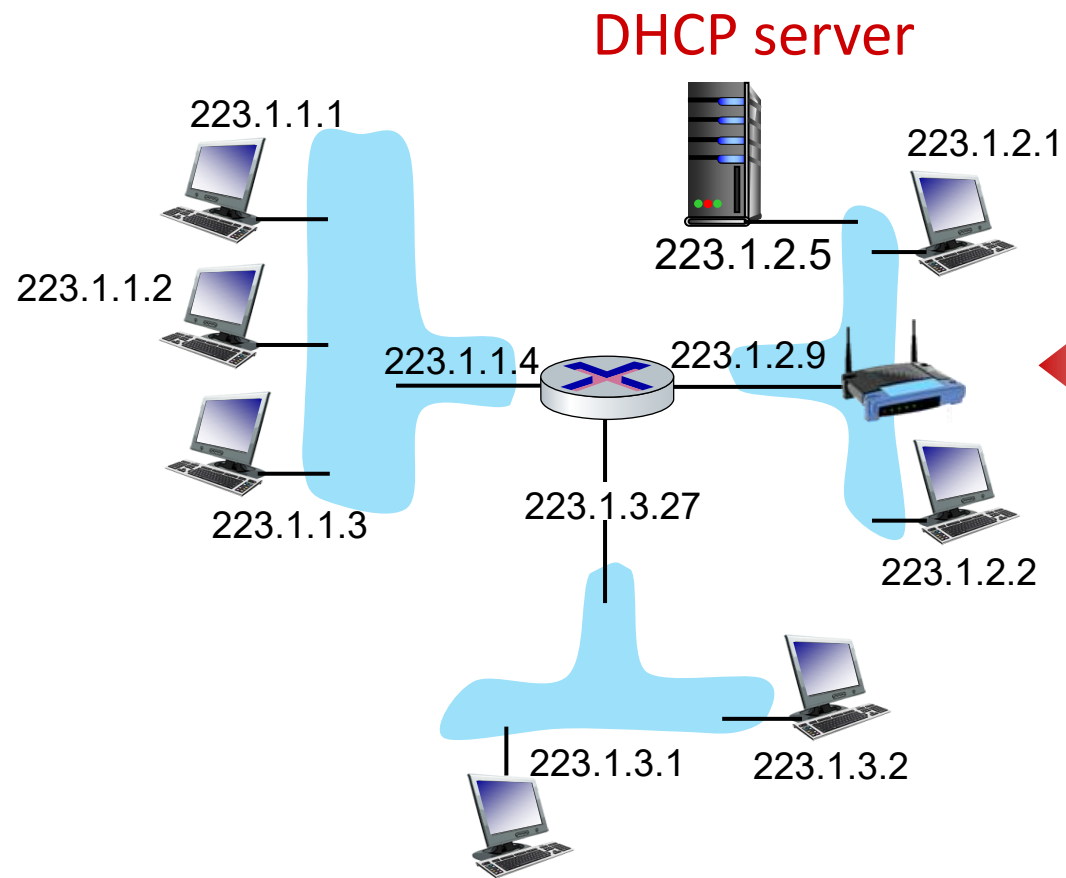
- can renew its lease on address in use
- allows reuse of addresses (only hold address while connected/on)
- support for mobile users who join/leave network

## DHCP overview:

- host broadcasts **DHCP discover** msg [optional]
- DHCP server responds with **DHCP offer** msg [optional]
- host requests IP address: **DHCP request** msg
- DHCP server sends address: **DHCP ack** msg



# DHCP client-server scenario



Typically, DHCP server will be co-located in router, serving all subnets to which router is attached

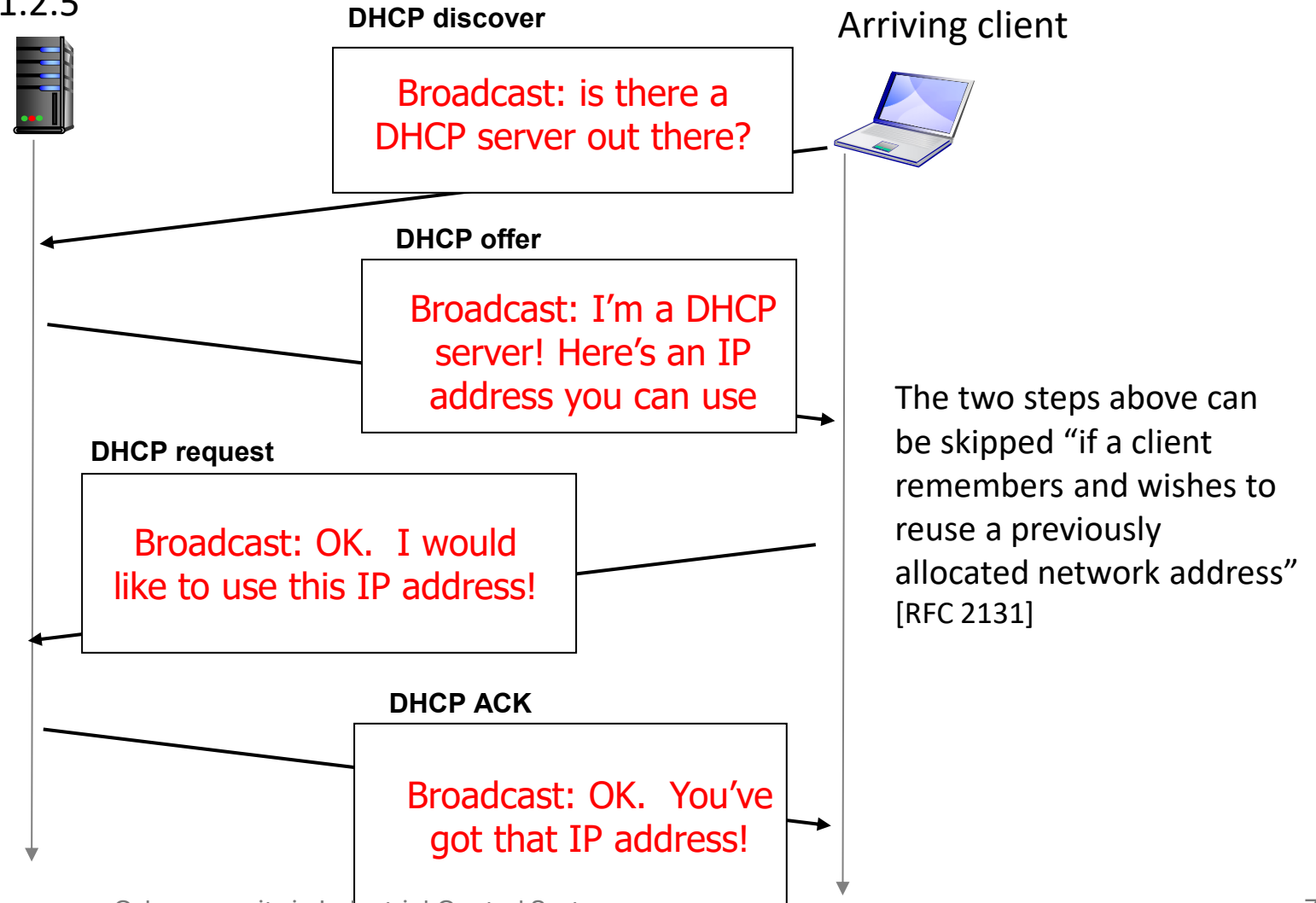


arriving **DHCP client** needs address in this network



# DHCP client-server scenario

DHCP server: 223.1.2.5





# DHCP: more than IP addresses

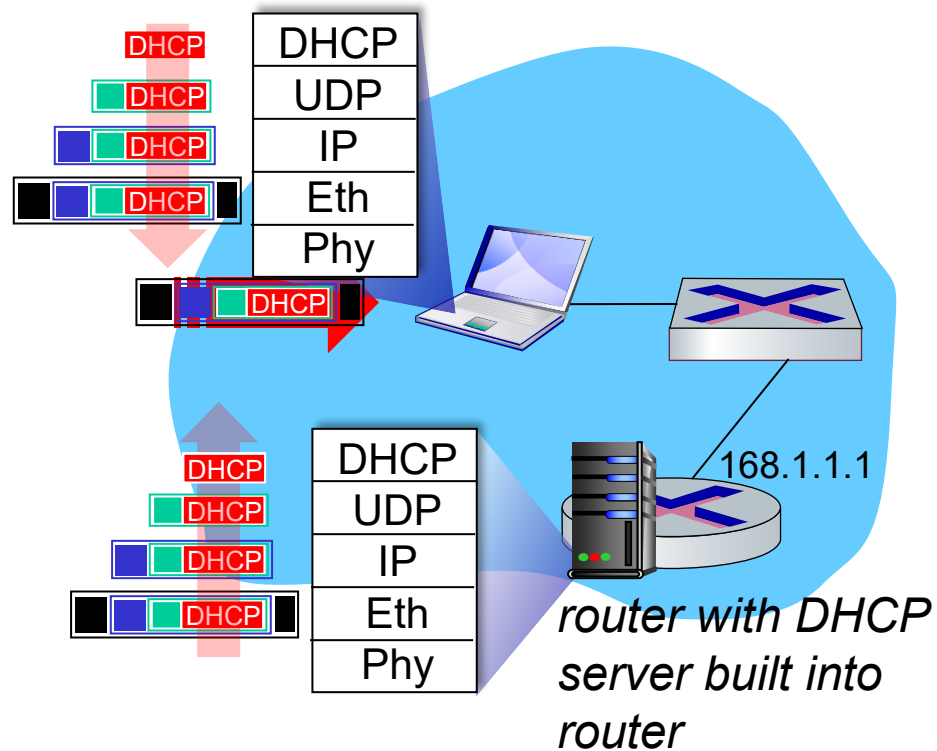
---

DHCP can return more than just allocated IP address on subnet:

- address of first-hop router for client
- name and IP address of DNS sever
- network mask (indicating network versus host portion of address)



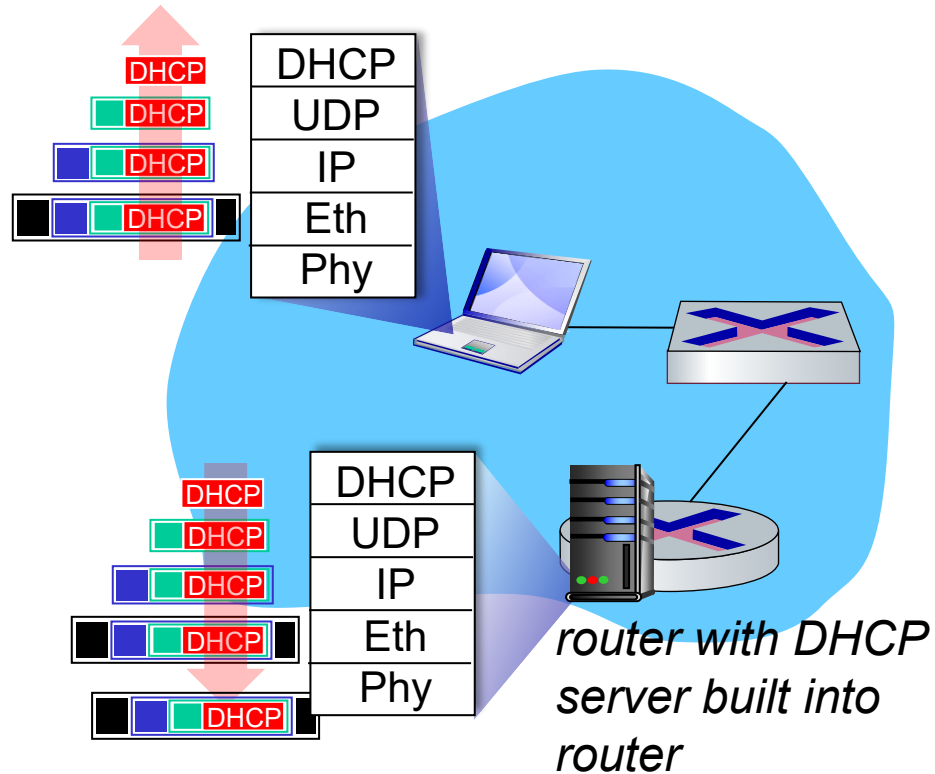
# DHCP: example



- Connecting laptop will use DHCP to get IP address, address of first-hop router, address of DNS server.
- DHCP REQUEST message encapsulated in UDP, encapsulated in IP, encapsulated in Ethernet
- Ethernet frame broadcast (dest: FFFFFFFF) on LAN, received at router running DHCP server
- Ethernet de-mux'ed to IP de-mux'ed, UDP de-mux'ed to DHCP



# DHCP: example



- DCP server formulates DHCP ACK containing client's IP address, IP address of first-hop router for client, name & IP address of DNS server
- encapsulated DHCP server reply forwarded to client, de-muxing up to DHCP at client
- client now knows its IP address, name and IP address of DNS server, IP address of its first-hop router



# Qu'est-ce que le Pentesting ?

**Pentesting** est l'abréviation de "**penetration testing**", en français **test d'intrusion**.

## Définition :

Le pentesting est une **méthode d'évaluation de la sécurité** d'un système informatique (réseau, application, matériel, etc.) en **simulant des attaques réelles** comme le ferait un hacker.

L'objectif est de :

- Identifier des **failles de sécurité**.
- Évaluer dans quelle mesure un **attaquant pourrait exploiter** ces vulnérabilités.
- **Prévenir des attaques** réelles en corrigeant les failles avant qu'elles ne soient exploitées.





# Qu'est-ce que le Pentesting ?

## Types de pentest :

- **Interne** : simulation d'un employé malveillant.
- **Externe** : simulation d'un attaquant externe (depuis Internet).
- **Boîte noire** : aucune info préalable.
- **Boîte grise** : quelques infos connues (comme un login).
- **Boîte blanche** : tout est connu, on teste en profondeur.



# Qu'est-ce qu'un Honeypot ?

## Définition :

Un **honeypot** (pot de miel) est un **système informatique piégé**, configuré pour **attirer les cyberattaquants**. Il simule des services ou des systèmes vulnérables **dans le but d'observer** les techniques utilisées par les attaquants.

## Objectifs d'un honeypot :

- **Attirer les hackers** pour analyser leurs comportements.
- **Détecter des attaques en temps réel.**
- **Améliorer les systèmes de défense** en comprenant les méthodes d'attaque.
- **Piéger les logiciels malveillants** ou scripts automatisés.



# Qu'est-ce que Conpot ?

## Définition :

**Conpot** est un **honeypot spécialisé dans les systèmes industriels** (ICS/SCADA). Il **simule des équipements industriels**, comme des automates programmables (PLCs), pour observer les tentatives d'intrusion.

→ Conpot est un **projet open-source** qui permet d'émuler différents types d'infrastructures critiques : réseaux d'eau, réseaux électriques, usines, etc.

## Fonctionnalités principales :

- Simule des **protocoles industriels réels**, comme **Modbus**, **S7comm**, **SNMP**, etc.
- Peut être **déployé sur un serveur Linux (ex. Ubuntu Server)**.
- Permet d'enregistrer les **logs d'attaques** pour analyse.
- Est souvent utilisé **dans les laboratoires** ou **les concours de cybersécurité** pour apprendre à détecter et comprendre les cyberattaques industrielles.



# Qu'est-ce que Snap7 ?

## Définition :

**Snap7** est une **bibliothèque open source** permettant la **communication directe avec les automates programmables Siemens S7** (notamment les **S7-300, S7-400, S7-1200, S7-1500**), via le protocole réseau **S7Comm**.

Elle permet d'échanger des données entre un ordinateur (client ou serveur) et un automate Siemens à travers le réseau **Ethernet**.

## Fonctionnalités principales :

### Simuler un automate (mode serveur)

- Snap7 peut être utilisé pour **créer un faux automate Siemens S7**.
- C'est utile pour les **tests de cybersécurité** ou pour **simuler une usine** dans un environnement de formation ou de développement.

### Communiquer avec un automate réel (mode client)

- Lire ou écrire des **données mémoire** d'un automate Siemens connecté au réseau.

### Tester et développer des outils de sécurité pour ICS



# À retenir

- Le honeypot **n'est pas un vrai système de production**, il est là pour **tromper** et **piéger** l'attaquant ou tester vos outils dans un environnement sécurisé.

Le conpot est utilisé dans votre TP pour :

- Créer un **faux automate Siemens** sur votre VM Ubuntu Server,
- Permettre aux autres outils (comme Nmap ou Metasploit) de l'analyser ou de le "pirater" dans un cadre **100 % sécurisé et légal**.

→ Conpot est votre **cible industrielle locale**, une "fausse usine" dans votre lab.



# À retenir

- Snap7 est installé dans le **TP1** pour préparer l'environnement,
- Et utilisé dans le **TP2** pour :
  - simuler un automate Siemens (avec un script Python),
  - ou interagir avec l'automate simulé via Conpot,
  - et tester des outils comme **plcscan**, **Nmap**, ou **Metasploit**.



# À retenir

Parce qu'un **PLC réel n'a pas d'interface graphique**

Parce qu'un **serveur est plus léger et efficace pour un honeypot**

**Pour prendre l'habitude de travailler en CLI**



## Ubuntu Desktop vs. Ubuntu Server : quelle différence ?

|  | Ubuntu Desktop                              | Ubuntu Server                                   |
|-----------------------------------------------------------------------------------|---------------------------------------------|-------------------------------------------------|
| Interface                                                                         | Avec interface graphique (GUI)              | En ligne de commande uniquement (CLI)           |
| Usage prévu                                                                       | Bureautique, navigation, multimédia         | Services réseau, serveurs, applications backend |
| Légèreté                                                                          | Plus lourd (RAM, CPU)                       | Plus léger, plus rapide                         |
| Paquets installés                                                                 | Beaucoup de logiciels graphiques par défaut | Juste l'essentiel (réseau, SSH, etc.)           |



# Metasploit Framework

Metasploit est une **plateforme open-source de tests d'intrusion** (pentesting), très puissante et largement utilisée par les professionnels de la cybersécurité.

## Objectif :

- **Identifier des failles de sécurité**
- **Exploiter des vulnérabilités connues**
- **Valider les protections** mises en place sur un système

## Fonctionnalités clés :

- Modules d'exploit pour des cibles variées (systèmes, logiciels, protocoles)
- Outils d'analyse, de scan et de post-exploitation
- Interface CLI : msfconsole





# plcscan.py

## Définition :

plcscan.py est un **script Python open-source** conçu pour **scanner des réseaux à la recherche d'automates industriels (PLCs)**, et en extraire des informations.

## Objectif :

- Repérer les équipements industriels (PLC) exposés
- Scanner des ports comme **102 (Siemens S7Comm)** ou **502 (Modbus)**
- Identifier le type d'équipement, version firmware, ID, etc.

Dans le TP, plcscan.py est utilisé pour :

- Scanner l'automate simulé (Conpot ou Snap7)
- Vérifier les ports ouverts
- Extraire des infos techniques sur le PLC



# Nmap (Network Mapper)

Nmap est un outil en ligne de commande pour **analyser des réseaux, découvrir des hôtes actifs, et scanner les ports ouverts.**

## Objectif :

- Identifier les machines connectées au réseau
- Savoir quels services/protocoles sont ouverts
- Détecter des signatures d'équipements industriels

Dans le TP, Nmap est utilisé pour :

- Découvrir le simulateur d'automate
- Scanner les ports 102 (S7Comm), 502 (Modbus), 161 (SNMP), etc.
- Utiliser des **scripts NSE spécialisés Siemens** pour aller plus loin